



Nationales Referenzprojekt
IT-Sicherheit in Industrie 4.0



Projektergebnisse

Inhalt

Werkzeuge	4
Executive Summary	4
Übersicht der Werkzeuge	5
Kategorie Werkzeuge zur Analyse der Sicherheit	6
Kategorie Werkzeuge für den Schutz von Systemen	9
Kategorie Werkzeuge für Angriffserkennung & Evaluation der Schutzmaßnahmen	28
Bewertung und Ausblick	38
Referenzen	40

Hauptansprechpartner:

Fraunhofer-Institut für Angewandte und Integrierte Sicherheit AISEC

Parkring 4

85748 Garching b. München

Telefon: +49 89 3229986-292

E-Mail: info@aisec.fraunhofer.de

Autoren des Dokuments:

DFKI:

Simon Duque Antón, Daniel Fraunholz, Christoph Lipps

Fraunhofer-Institut für Angewandte und Integrierte Sicherheit AISEC:

Daniel Angermeier, Bartol Filipovic, Alexander Giehl, Johannes Obermaier, Peter Schneider, Dieter Schuster, Norbert Wiedermann

Fraunhofer-Institut für Experimentelles Software Engineering IESE:

Manuel Rudolph

Infineon Technologies AG:

Hans Brandl, Florian Schreiner

Siemens AG:

Kai Fischer, Daniela Friedrich

Technische Universität München, Lehrstuhl für Sicherheit in der Informatik I20:

Bruno Bierbaumer, Mohammad Reza Norouzian

Universität Kassel, Projektgruppe verfassungsverträgliche Technikgestaltung (provet):
Johannes Müller

WIBU Systems AG:
Günther Fischer, Wolfgang Neifer

Werkzeuge

Executive Summary

In IUNO wurden Werkzeuge und Lösungsbausteine erarbeitet und erprobt, die für die Analyse der Sicherheit und der Erfassung von Sicherheitsanforderungen dienen und auch der Schutz von Systemen einerseits und die Angriffserkennung und Evaluation der Schutzmaßnahmen andererseits wurden betrachtet. Einige Werkzeuge sind in ihrer Handhabbarkeit recht weit entwickelt und kommen bspw. in den vier Anwendungsfällen von IUNO zum praktischen Einsatz. Bei manchen Entwicklungen handelt es sich um anwendungsnahe Vorlaufforschung, die in Laboraufbauten auf Praxistauglichkeit getestet und optimiert werden. Die Zielsetzung von IUNO war es entsprechend auch - soweit möglich - relevante Bausteine zu identifizieren, Entwicklungen anzustoßen und erste Tests durchzuführen. Auf Grundlage der erarbeiteten sind nun Transfermöglichkeiten gegeben, um Lösungsbausteine in einem breiteren Umfeld einzusetzen.

Um Angriffe auf viele Industrie 4.0 Systembereichen zu erkennen und somit die Integrität von Produktionsanlagen und zugehörigen Diensten sowie Prozessen zu erhalten, dienen beispielsweise Werkzeuge mit denen vernetzte Produktionsanlagen simuliert werden können. So dienen dann beispielsweise Honeynets zur Detektion von Angriffen. Es werden technische Konzepte zur Überwachung der Geräte-/Systemintegrität zur frühzeitigen Angriffserkennung beschrieben und die dafür definierten Mechanismen und Konzepte implementiert.

Die Werkzeugkastenelemente für Schutzmaßnahmen können unterschiedliche Ausprägungen haben. Es kann sich beispielsweise um Umsetzungsempfehlungen, organisatorische Maßnahmen, technische Konzepte, kommerzielle Produkte oder auch neue prototypische Implementierungen handeln.

Für ein flexibles und personalisiertes Identitäts- und Trustmanagement von verschiedenen Anwendungen auf einem System, wie es zum Beispiel im Demonstrator „Vernetzte Produktion“ implementiert werden soll, ist eine angemessene Isolation der einzelnen Komponenten eines Systems notwendig. So ist es z.B. problematisch, wenn die Speicherung der geheimen Identitätsschlüssel eines Systems so innerhalb des Systems erfolgt, dass ein Angreifer Zugang zu diesem Schlüsselmaterial erlangen kann. In den IT-Infrastrukturen, welche schon heute hochgradig vernetzt sind, wurden daher verschiedene Techniken entwickelt, um die Isolation einzelner Komponenten eines Systems voneinander abzuschotten. Dadurch wird eine Verringerung der Angriffsfläche geschaffen. Die Kompromittierung einer isolierten Komponente hat dann keine Auswirkungen auf das restliche System, so dass auch eine zielgerichtete und effiziente Fehlerbehebung möglich wird. Es wurden verschiedene Isolationstechniken, wie container- oder hypervisor-basierte Lösungen auf Anforderungen aus der Industrie4.0 geprüft. Zusätzlich eröffnet sich durch die Isolierung verschiedener Bereiche auch Möglichkeiten zur sicheren Analyse (Attestation) und Überwachung eines Systems. Dies ist vor allem für das Trustmanagement und die Anomalie Erkennung von hoher Bedeutung, da zu jeder Zeit eine Aussage über die Integrität der verwendeten Komponenten gemacht werden muss. Mit Hilfe von Systemvirtualisierungslösungen und Virtual Machine Introspection (VMI) soll daher die Integrität der Komponenten sichergestellt werden. Diese Isolations- und Überwachungstechniken sind dann auf verschiedenen Ebenen des Wertschöpfungsnetzwerkes einsetzbar.

Ein weiteres Ziel ist der Aufbau von prototypischen industriellen Security Komponenten. Dies umfasst Hard- und Software zur eindeutigen Geräteidentifikation und kann sichere

Kommunikationsverbindungen zwischen den Funktionsblöcken des Demonstrators aufbauen. Darüber hinaus sind beispielsweise auch eine Nutzungskontroll-Komponente sowie ein Policy-Editor ein Teil der betrachteten Lösungen.

Die Sicherheit von Geräten profitiert von hardwarebasierten Vertrauensankern. Aus Anforderungen an unterschiedlichen Einsatzzwecke wurden Einsatzmöglichkeiten für solche Vertrauensanker abgeleitet. Durch Anwendung von neuesten Silizium-Technologien wurde an einem Sicherheitschip (Industrial Trusted Platform Module) gearbeitet, der eine hohe Sicherheit bietet und für die Anwendung im industriellen Umfeld optimiert ist. Dabei war eine Integration/Verkleinerung der Sicherheitsprozessoren angestrebt und damit eine Verringerung der Produktionskosten. Für die Anwendung der neuen Sicherheitsprozessoren werden dabei verfügbare Technologien genutzt und weiter darauf aufgebaut. Dabei werden auch Trusted Computing Technologien berücksichtigt und internationale Standards wie dem ISO-Standard ISO/IEC 11889.

Auch rechtliche Aspekte wurden im Rahmen von IUNO betrachtet. In enger Zusammenarbeit mit den technischen Projektpartnern sind technische Gestaltungsziele aus den Anwendungsfällen zu Gestaltungsvorschlägen weiter konkretisiert worden, um so bei der Auswahl von rechtskonformen Werkzeugen unterstützen zu können. Anhand der Gestaltungsvorschläge können einerseits existierende Werkzeuge rechtlich evaluiert und bei Bedarf rechtskonform umgestaltet werden. Andererseits können auch auf Grundlage der Gestaltungsvorschläge völlig neue Werkzeuge gestaltet werden, die dann von Beginn an rechtskonform sind.

Es erfolgten sowohl Methodenentwicklungen als auch softwarebasierte Lösungsansätze für Bedrohungs- und Risikomodelle, die eine Beurteilung von Bedrohungen und Schutzzielen im industriellen Kontext ermöglichen. Über Gewichtungen der einzelnen Eingabeparameter erfolgt dann eine automatische Bewertung die dann zur Entwicklung von Gegenmaßnahmen genutzt werden kann.

Es kommen Evaluationswerkzeuge zum Einsatz mit denen Angriffe auf ausgewählte Industrie 4.0 Systemebenen durchgeführt werden können (bspw. Penetrationstests). Die Werkzeuge sind bedarfsorientiert und wurden bspw. bei Sicherheitsanalysen von Demonstratoren in IUNO eingesetzt.

Übersicht der Werkzeuge

Hier zunächst eine Auflistung von ausgewählten Werkzeugen und Lösungsbausteinen, die in IUNO erarbeitet wurden und die in den nachfolgenden Abschnitten dann genauer beschrieben werden. Die Beiträge in diesem Bericht wurden jeweils von den in Klammern angegebenen Projektpartnern verfasst.

Werkzeuge zur Analyse der Sicherheit:

- Softwaretools für Bedrohungs- und Risikoanalyse (Fraunhofer AISEC)
- Leitlinien für rechtsverträgliche Gestaltung (Universität Kassel, provet)

Werkzeuge für den Schutz von Systemen:

- Industrial Trusted Platform Module (Infineon Technologies AG)
- Durchsetzung von Datennutzungsrichtlinien (Fraunhofer IESE)
- Virtualisierung von Industrieanwendungen (Fraunhofer AISEC, TU München)
- Angriffserkennung & Absicherung der Feldbuskommunikation (Fraunhofer AISEC)

- Automatische Firmware-Analyse / Malwareanalyse (TU München)
- Schlüsselerzeugung aus Funkkanal (DFKI)
- Isolationsmaßnahmen (TU München)
- Softwareschutz und -lizenzierung (WIBU Systems AG)
- Sichere Datenspeicherung und Deployment (WIBU Systems AG)

Werkzeuge für Angriffserkennung und Evaluation der Schutzmaßnahmen:

- Industrielles Honeynet (DFKI)
- Anomalieerkennung für industrielle Steuerungssysteme (DFKI, TU München)
- Simulation von Produktionsnetzwerken (Fraunhofer AISEC)
- Pentesting von industriellen Steuergeräten (Fraunhofer AISEC)
- Integritätsüberwachung (Siemens)

Kategorie Werkzeuge zur Analyse der Sicherheit

Softwaretools für Bedrohungs- und Risikoanalyse (Fraunhofer AISEC)

Für die Entwicklung sicherer Systeme („Security by Design“) ist eine frühe Kenntnis und Abschätzung von Security-Risiken maßgeblich. In IUNO wurde die etablierte Risikoanalyse-Methode **Modular Risk Assessment (MoRA)** (Eichler & Angermeier, 2015) auf das Anwendungsfeld Industrie 4.0 angepasst und durch eine konkrete Anwendung erprobt. Eine Risikoanalyse nach MoRA umfasst die in Abbildung 1 gezeigten Aktivitäten.

Hierbei wird zunächst der Untersuchungsgegenstand durch Security-Experten und Entwickler des zu untersuchenden Systems gemeinsam modelliert. Dieser Modellierungsschritt führt zu einem gemeinsamen Systemverständnis der verschiedenen Domänen-Experten und schafft eine Grundlage für eine weiterführende systematische Untersuchung der Security-Risiken. Für das modellierte System werden anschließend die Schutzziele ermittelt, indem für die modellierten Systemelemente alle relevanten Security-Attribute (wie z.B. Vertraulichkeit, Verfügbarkeit, oder Integrität) untersucht und die Schäden bei einer Verletzung dieser Schutzziele festgelegt werden. Hierfür wird auf einen Katalog möglicher Schäden zurückgegriffen, für die jeweils auch eine Schadenshöhe festgelegt ist. Weiterhin werden mögliche Bedrohungen auf das System identifiziert, indem Angriffe auf die Komponenten oder Schnittstellen des Systems systematisch untersucht werden. In diesem Zusammenhang werden auch vorhandene oder geplante Security-Maßnahmen mit einbezogen. Für jede Bedrohung wird zudem festgelegt, welche Schutzziele durch die jeweilige Bedrohung verletzt werden können. Eine Abschätzung der Wahrscheinlichkeit eines erfolgreichen Angriffs, beispielsweise basierend auf den benötigten Fähigkeiten eines Angreifers, ermöglicht schließlich die Abschätzung der Risiken. Im nächsten Schritt kann dann eine Risikobehandlung erfolgen, deren Wirksamkeit in einer iterativen Anpassung der Risikoanalyse untersucht werden kann.

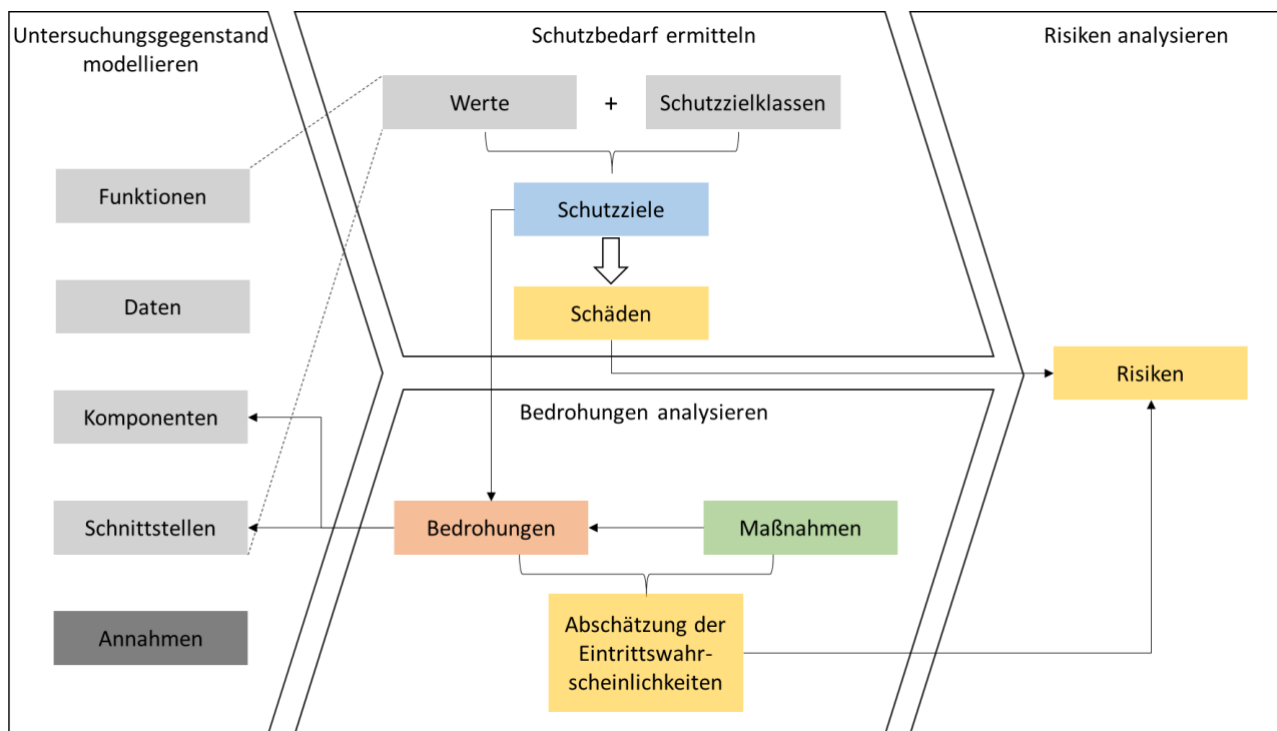


Abbildung 1 - Hauptaktivitäten von MoRA

In IUNO wurden für die Anwendbarkeit der Methode im Umfeld von Industrie 4.0 wichtige Grundlagen für die Wiederholbarkeit und Vergleichbarkeit von Risikoanalyse mit MoRA geschaffen. Insbesondere wurde mit den Projektpartnern ein repräsentatives Bewertungsmodell erarbeitet, welches bei der Abschätzung von Schäden und Eintrittswahrscheinlichkeiten eine zentrale Rolle spielt. Hierunter fällt insbesondere eine Auflistung möglicher Schäden, die in der Anwendungsdomäne bei Verletzung von Schutzzielen entstehen können, sowie eine Einstufung dieser Schäden in Schadenshöhen. Dies schafft eine gemeinsame Grundlage für die Abschätzung von Schäden, die auf Ebene fachlicher Grundlagen diskutiert werden kann und den subjektiven Anteil der Abschätzungen durch einzelne Analysten minimiert. Eine gemeinsame Anwendung der Methode für zwei Demonstrator-Entwicklungen konnte die Anwendbarkeit der Methode aufzeigen.

Für die konkrete Anwendung des Lösungsbausteins ist eine Integration der Methodenanwendung in den Entwicklungsprozess des Unternehmens nötig. Hierbei muss die Durchführung durch Security-Experten des Unternehmens getrieben werden. Zusätzlich ist eine aktive Beteiligung der Systementwickler an der Modellierung des Untersuchungsgegenstands und der Ermittlung des Schutzbedarfs notwendig. Im Gegenzug entsteht eine fachlich fundierte und für die Entwickler nachvollziehbare Risikoanalyse, die bei der nachfolgenden Risikobehandlung dabei unterstützt, gut informierte und wohlbegründete Entscheidungen zu treffen.

Leitlinien für rechtsverträgliche Gestaltung (Universität Kassel provet)

Die Rechtsverträglichkeit der technischen Lösung zielt auf die optimale Umsetzung rechtlicher Anforderungen ab, um gesellschaftliche Risiken von Techniksystemen bestmöglich zu minimieren. Zur rechtsverträglichen Gestaltung wurde von provet die Methode zur **Konkretisierung rechtlicher**

Anforderungen (KORA) entwickelt und bereits vielfach erfolgreich angewendet.¹ Mit ihrer Hilfe werden abstrakte rechtliche Regeln schrittweise zu technischen Gestaltungsvorschlägen konkretisiert.

Als Ausgangspunkt der Methode werden zunächst *verfassungsrechtliche Vorgaben* (etwa Grundrechte des Grundgesetzes oder der Europäischen Grundrechtecharta), die von der in den Demonstratoren verwendeten Technik berührt werden, dargestellt. Aus diesen werden die in ihnen enthaltenen sozialen Funktionen herausgearbeitet. Dieses höchstrangige Recht ist dauerhaft und verbindlich. Es ist verbürgter gesellschaftlicher Konsens dessen, was die Gesellschaft als Rechtsrahmen gemeinverbindlich akzeptiert. Darum ist es der Ausgangspunkt der rechtsverträglichen Technikgestaltung. Einfache Gesetze (z.B. DSGVO, BDSG, BSIG, TKG, TMG) dagegen füllen ihrerseits die sozialen Funktionen der Grundrechte aus. Sie sollen die Verwirklichung der Grundrechte fördern und deren Beeinträchtigung verhindern, sind aber selbst zeitlich wesentlich unbeständiger.

Sodann werden Chancen und Risiken der Demonstratoren für die Funktionen dieser Vorgaben eruiert. Aus ihnen werden *rechtliche Anforderungen* (KORA Stufe 1) an die Technik abgeleitet, die diese erfüllen muss, damit die sozialen Funktionen der grundrechtlichen Vorgaben nicht beeinträchtigt werden oder damit zu deren Verwirklichung durch die Technik selbst beigetragen werden kann.

Im nächsten Schritt werden hieraus spezifische und konkrete *rechtliche Kriterien* (KORA Stufe 2) erarbeitet, die bei der Gestaltung der Technik beachtet werden müssen. Sie werden gewonnen, indem nach Regeln gesucht wird, nach denen die grundrechtlichen Anforderungen gegenüber den besonderen Eigenschaften, Risiken und Anwendungsbedingungen der Demonstratorentechnik erfüllt werden können. Sie dienen als Leitlinien bei der Bewertung und Gestaltung der Technik. In Betracht kommen hierbei als Regeln insbesondere die einfachgesetzlichen Normen.

Die auf diese Weise erarbeiteten Kriterien werden durch die Projektpartner mit technischen-generellen Lösungen „gematcht“, das heißt es wird der rechtliche Input in technische Lösungsmöglichkeiten übersetzt. Die Übersetzungsarbeit liegt darin, die rechtlichen Kriterien in Form von *technischen Gestaltungszielen* (KORA Stufe 3) auszudrücken.

Auf der letzten Ebene werden dann konkret geeignete technische Lösungen, die *technischen Gestaltungsvorschläge* (KORA Stufe 4), zur Umsetzung der Kriterien hervorgebracht. Sie setzen die rechtlichen Kriterien vollständig um und führen damit zu einem „Mehr“ an Rechtsverträglichkeit im Rahmen der Demonstratoren.

¹ Beispielsweise, *Hammer/Pordesch/Roßnagel*, Betriebliche Telefon- und ISDN-Anlagen rechtsgemäß gestaltet, Berlin 1993; *Idecke-Lux*, Der Einsatz von multimedialen Dokumenten bei der Genehmigung von neuen Anlagen nach dem Bundesimmissionsschutz-Gesetz, 1999; *Schwenke*, Individualisierung und Datenschutz. Rechtskonformer Umgang mit personenbezogenen Daten im Kontext der Individualisierung, 2006; *Richter*, Wahlen im Internet rechtsgemäß gestalten, Baden-Baden 2012; *Geminn*, Rechtsverträglicher Einsatz von Sicherheitsmaßnahmen im öffentlichen Verkehr, 2014 und viele weitere.

Kategorie Werkzeuge für den Schutz von Systemen

Industrial Trusted Platform Module (Infineon Technologies AG)

Die Sicherheit aktueller Steuerungen und Prozessoren in industriellen Anlagen beruht im Wesentlichen auf der gegen Manipulationen geschützten Implementierung von Daten und Anweisungen in Halbleiter basierten Prozessoren. Mittlerweile stehen aber auch die vielfältigen Verfahren zur Analyse und Debugging, die bei der Entwicklung und Produktion solcher Chips nötig sind, auch für Angriffe im sicherheitsrelevanten Bereich zur Verfügung. Dadurch könnten Sicherheitsstrukturen, Daten oder im schlimmsten Falle kryptographisches Schlüsselmaterial aus einem Standardkontroller ausgelesen oder geändert werden, und damit die Sicherheitsfunktionen von Hardware und Software umgangen werden, oder Manipulationskanäle angelegt werden. Damit lassen sich z.B. intelligente Angriffspforten installieren, die bei Bedarf und ferngesteuert das komplette Sicherheitssystem lahmlegen oder umgehen. Ziel einer Attacke ist dabei im schlimmsten Falle die möglichst spurlose Ersetzung der Systemintegrität nur für die Zeit des Angriffs und der Ersatz durch eine möglichst nicht einfach erkennbare dauerhafte Angriffsfunktionalität, sodass auch später im laufenden Betrieb einer Anlage durch Anweisungen des Angreifers Code und Daten zum Transport des Angriffs in seinem Sinne problemlos verändert werden können.

Um solche Angriffe zu verhindern, wurden bereits vor 20 Jahren spezielle Sicherheitsprozessoren vor allem für den werthaltigen Zahlungsverkehr entwickelt, die Angriffe physikalisch oder logisch erkennen können und dazu Gegenmaßnahmen einleiten (aus prinzipiellen Gründen ist es nicht möglich, Angriffe komplett zu verhindern. Was man als Implementierung in der zur Verfügung stehenden Technik realisiert, kann man in der Regel mit denselben Technologien als Entwicklungswerkzeug auch wieder analysieren und damit verändern bzw. angreifen). Aufbauend auf den dabei entwickelten Grundlagen wurde als internationaler Standard ISO 11889 deshalb ein System eines parallelen kryptographischen Sicherheitsprozessors in einer vertrauenswürdigen Technologie entwickelt (Trusted Computing der <https://Trustedcomputinggroup.org> [TCG]), der die nötigen kryptographischen Sicherheitsverfahren in einem geschützten Halbleiter-Sicherheitsprozessor bereitstellt und zugleich Angriffe weitgehend erkennen kann. Dieser offene, lizenzfreie Standard verfügt über ca. 150 typische Teilalgorithmen mit den international üblichen und evaluierten Kryptoverfahren, die je nach Bedarf in einem Trusted Computing Prozessor implementiert werden können. Ein wesentlicher Unterschied zu den bis dahin üblichen direkten Sicherheitsprozessoren besteht darin, dass zusätzlich die Erkennung der Integrität des Systems und damit die Warnung bei Veränderung des Systems als Teil der Sicherheits-Implementierung möglich ist.

Im Industrial Plattform Module (iTPM), das in IUNO entwickelt wurde, wurden die für den industriellen Einsatz relevanten Funktionen und Algorithmen der ISO 11889 in einem sicherheitstechnisch gehärteten Prozessor, speziell für den Einsatz in einer industriellen Produktionsumgebung implementiert. Die Funktionalität des Prozessors wurde mit der Compliance Testsuite der TCG auf Korrektheit der Implementierung überprüft. Für die Resistenz gegen Angriffe, d.h. die Konformität der Implementierung mit dem Schutzprofil der TCG, wurde im externen Zertifizierungsverfahren nach ISO/IEC 15408, Stärke EAL-4, die Sicherheit gegen bekannte Angriffsverfahren analysiert und getestet.



Abbildung 2 : Industrial TPM Chip, vergrößert; Abmessungen ca. 6mm x 6mm

Dazu wurde das Produkt zuerst von einer akkreditierten Prüfstelle geprüft und anschließend dann beim BSI als nationale, oberste Zertifizierungsinstanz zertifiziert. Diese Sicherheitszertifizierung wird weltweit anerkannt.

Das iTPM ist als separater geschützter Prozessor mit 50 MHz Taktrate und SPI Interface implementiert und kann damit zusammen mit allen üblichen Prozessoren als zusätzliche Sicherheitskomponente betrieben werden.

Standardanwendungen sind:

- Überprüfung der Bootsequenz beim Einschalten (z.B. Erkennen von Bootviren oder –angriffen) zur Verifizierung der Systemintegrität.
- Bereitstellung der international akzeptierten kryptographischen Algorithmen für Verschlüsselung und Signatur wie z.B. RSA, Elliptische Kurven und AES in einer sicheren Implementierung
- Erzeugung von sicheren Schlüsselmaterial und kryptographischen Zertifikaten
- Identifizierung von Peripheriebausteine durch Sicherheits-Identitäten
- Sicheres Speichern von Schlüsseln, Zertifikaten und kritischen Daten
- Nichtflüchtiger Halbleiterspeicher zum Erhalt der Daten auch ohne Betriebsspannung, z.B. für die Systemkonfiguration.
- Abfrage der korrekten Integrität mit sicheren Protokollen

Eine sehr gute Übersicht in das wegen seiner Anwendungsbreite und Funktionalität sehr komplexe Thema der Anwendung/Programmierung des iTPM nach ISO11889 findet sich in (Arthur & Challenger). Das Buch ist sowohl im Buchhandel erhältlich, kann aber auch im Internet als ApressOpen ebook kostenlos heruntergeladen werden.

Für die Entwicklung der Anwendungssoftware des iTPM können durch die Verwendung des ISO 11889 Standards je nach Bedarf die freien Entwicklungsunterstützungen von Microsoft, IBM und Intel verwendet werden. Der Umfang der damit entwickelten Anwendungs-Software wächst ständig

und auch die Software-Teile die mit Hilfe des IUNO-projekts entwickelt wurden, stehen als Open Source für die Gemeinschaft zur Verfügung.

In der Zusammenarbeit zwischen dem Fraunhofer SIT und Infineon werden derzeit auch noch nach Ende des IUNO-Projekts für den iTPM offene Referenzimplementierungen von typischen Sicherheitsfunktionen entwickelt und Interessenten frei zur Verfügung gestellt. Damit soll dem späteren Systementwickler, der nicht unbedingt ein Kryptographie-Spezialist ist, erprobte Code-Beispiele zur Verfügung gestellt werden und ihm so das Leben einfacher gemacht werden. Die wesentlichen Ergebnisse sind zu finden in: <https://github.com/tpm2-software>. Einige Anwendungsbeispiele aus dieser Kampagne sind nachfolgend als weitere Werkzeuge beschrieben.

Explizite Funktionsaufrufe der wichtigsten iTPM Funktionen

Die „[ELTT2 - Infineon Embedded Linux TPM Toolbox 2 for iTPM 2.0](#)“² enthält Code Beispiele für fast alle Funktionsaufrufe des iTPM und ist zu finden unter. Sie enthält jeweils den Code für fast alle individuellen iTPM Funktionen.

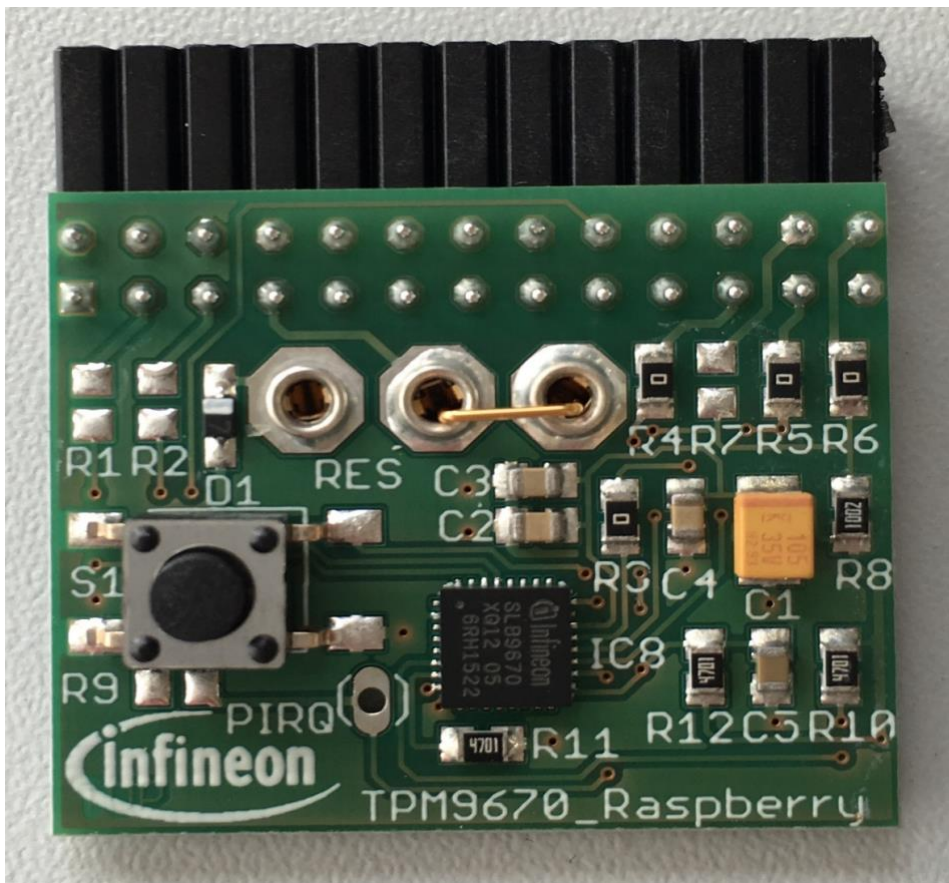


Abbildung 3 : Steck-Testbaugruppe mit dem iTPM für die Raspberry Pi Controller Platform

Für erste Anwendungen und Erfahrungen stehen Steckmodule mit dem iTPM zur Verfügung, die auf den Raspberry PI Controller passen.

² <https://github.com/Infineon/eltt2>

In der Toolbox finden sich zudem alle Beschreibungen und Hinweise für das Konfigurieren und Aufsetzen des Raspberry.

Anwendungsbeispiel: Sicherer und vertrauenswürdiger https-Webserver mit Raspberry Pi und iTPM

Für das Anwendungsbeispiel „Sicherer und vertrauenswürdiger https-Webserver mit Raspberry Pi und iTPM“ steht eine Implementierung (Embedded Linux, Open Source Code) unter der URL [Infineon SLB 9670 TPM 2.0 on a Raspberry Pi 3 EN³](https://www.infineon.com/dgdl/Infineon-SLB9670-TPM2.0-on-a-Raspberry-Pi-3-EN3) zur Verfügung. Der Beispielcode enthält:

- Typische Sicherheitsanwendungen (Quellcode für Embedded Linux) auf einem sicheren und vertrauenswürdigen Computer, bestehend aus Raspberry Pi mit Trusted Computing Chip
- Die implementierten Sicherheitsbeispielprogramme haben einen typischen Querschnitt vertrauenswürdiger Anwendungen:
- Vertrauenswürdiger und sicherer https Web Server
- Serverauthentifizierung SSL / TLS
- Sicherer Schlüsselaustausch
- Sicheres Software-Update

Die genannte URL enthält neben dem Quellcode auch Dokumentation. Ein Evaluierungsboard ist verfügbar über den Infineon Support.



Abbildung 4: Raspberry 3 mit Infineon TPM 2.0 Adapter Board

Referenzimplementierung OpenSSL im iTPM Trusted Platform Module

OpenSSL ist eine Open-Source-Version des SSL/TLS-Protokolls, und hat die Aufgabe, sichere, verschlüsselte Verbindungen aufzubauen. SSL wird vor allem bei HTTP, aber auch bei

³ https://www.infineon.com/dgdl/Infineon-TPM20_SLB6970-AN-v01_00-EN.zip?fileId=5546d4625acbae4c015ad6d953664083

Applikationen wie z.B. SSH und OpenVPN eingesetzt, generell bei der Authentisierung von Plattformen und dem Aufbau sicherer Verbindungen.

Demgemäß ist es eine der wichtigsten Sicherheits-Querschnittfunktion für sichere Industrie4.0 Anwendungen, da der Aufbau und die Verwaltung der Verbindung zu entsprechenden Instanzen eine grundlegende Basis für IT-Sicherheit darstellen.

Es enthält alle Funktionen zum Aufbau einer sicheren oder verschlüsselten Verbindung zwischen zwei Computersystemen wie Schlüsselerzeugung, sicherer Schlüsselaustausch, Signaturen und Verifizierung als auch sichere (verschlüsselte und signierte) Datenübertragung.

Um den potentiellen Anwender des iTPM, der nicht unbedingt der absolute Kryptographie-Spezialist ist, bei der Systementwicklung zu unterstützen wurde in diesem Teilprojekt OpenSSL/tpm2-tss-engine deshalb eine komplette Referenzimplementierung mit dem vollen Code Umfang erstellt, die breit eingesetzt werden kann.

Der vollständige Quellcode und die Installationsanweisungen sind enthalten in:

<https://github.com/tpm2-software/tpm2-tss-engine>

Das Projekt tpm2-tss-engine implementiert eine kryptographische Engine für OpenSSL für das Trusted Platform Module (TPM 2.0) mit dem tpm2-tss-Software-Stack, der dem Trusted Computing Groups (TCG) TPM-Software-Stack (TSS 2.0) folgt. Es verwendet die ESAPI-Schnittstelle (Enhanced System API) des TSS 2.0 für die Abwärtskommunikation. Es unterstützt RSA-Entschlüsselung und Signaturen sowie ECDSA-Signaturen.

Die von dieser Engine verwendeten Schlüssel befinden sich alle unter einem mit ECC-gesicherten rootkey Entschlüsselungsschlüssel. Dieser Schlüssel wird bei jedem Aufruf erstellt (da die Erstellung des ECC-Schlüssels schneller als die von RSA ist). Daher muss kein persistenter SRK-Schlüssel vordefiniert werden.

Die RSA-Schlüssel werden mit der Fähigkeit erstellt, sowohl zu signieren als auch zu entschlüsseln. Dadurch können alle RSA-Schlüssel für beide Operationen verwendet werden. Die ECDSA-Schlüssel werden als ECDSA-Schlüssel mit der Fähigkeit zum Ausführen von Signaturoperationen erstellt.

Anweisungen zum Erstellen und Installieren von tpm2-tss sind in der INSTALL-Datei verfügbar.

Anwendungsbeispiele sind:

- Erstellen von Zufallstext (z.B. zur Schlüsselerzeugung), ein Satz von 10 zufälligen Bytes kann abgerufen werden.
- RSA entschlüsseln. Mit Hilfe des iTPM wird einen RSA-Schlüssel erstellt, der öffentlichen Schlüssel exportiert, eine Datendatei verschlüsselt und entschlüsselt sie mithilfe des iTPM
- RSA Signatur. Erstellt einen RSA-Schlüssel mit Hilfe des iTPM, exportiert den öffentlichen Schlüssel, signiert eine Datendatei mithilfe des TPM und validiert die Signatur.
- ECDSA-Operationen. Erstellung eines ECDSA-Schlüssel mithilfe des iTPM, exportieren des öffentlichen Schlüssel, signieren einer Datendatei mithilfe des TPM und Validierung der Signatur.

Durchsetzung von Datennutzungsrichtlinien (Fraunhofer IESE)

Verteilte Datennutzungskontrolle (engl. Distributed Data Usage Control) ermöglicht es, die Verbreitung und Verwendung von Daten und Informationen nach dem Zugriff zu kontrollieren. Die grundlegende Idee besteht darin, dem Dateneigentümer umfassende Kontrollmöglichkeiten zu geben, die weitere Nutzung seiner Daten zu steuern. Hierzu werden klassische Zugriffskontrollmechanismen (engl. Access Control) erweitert, so dass der Dateneigentümer die Daten aus der Hand geben kann und dennoch die Kontrolle über deren Nutzung behält: „Share your data, but keep control!“ Datenmissbrauch ist eine große Sorge bei der Informationsverarbeitung. Auf ungewünschten Datenabfluss oder unberechtigte Datennutzung können finanzielle Schäden folgen, zum Beispiel im Falle von Wirtschaftsspionage, rechtlichen Verstößen oder einer versehentlichen Veröffentlichung von sensiblen Dokumenten durch eigene Mitarbeiter.

Das am Fraunhofer IESE entwickelte Sicherheitsframework IND²UCE macht Datennutzungskontrolle praktisch nutzbar. Dabei kann eine Datenverwendung nicht nur erlaubt oder verboten werden, sondern auch eine Modifikation der Daten vor ihrer Verwendung ist durchsetzbar. Somit können Daten zum Beispiel on-the-fly anonymisiert, pseudonymisiert oder aggregiert werden. Zudem kann eine situationsabhängige oder zweckgebundene Datennutzung ebenso durchgesetzt werden, wie eine zeit- oder kardinalitätsbasierte Einschränkung der Datennutzung. Zur Entscheidungsfindung, welche Datenströme wann erlaubt oder verboten und wie modifiziert werden, können weitere Informationsquellen (z. B. Rollen von Personen oder Lizenzinformationen) herangezogen werden. Des Weiteren können zusätzliche Aktionen (z. B. Benachrichtigungen oder Logging) ausgelöst werden.

Das IND²UCE-Framework besteht aus drei Bausteinen (siehe Abbildung 5):

Policy Language: Die IND²UCE Policy-Sprache ist ein mächtiges Instrument, um vielfältige Kontrollmöglichkeiten für die eigenen Daten als Sicherheitsrichtlinien zu spezifizieren. Sie folgt einer einfachen IF-THEN-ELSE Struktur im XML-Format, unterstützt jedoch gleichzeitig eine Vielzahl an Mechanismen um auch komplexe Sachverhalte abzubilden. Es können sowohl vielfältige Bedingungen (z.B. erlaubte Nutzungssituationen, zeitliche und mengenbezogene Nutzungsbeschränkungen) als auch Aktionen (z.B. Datenfilterung, Datenmaskierung, Benachrichtigungen, Datenlöschungen) definiert werden.

Policy Management: Sowohl die Sicherheitsrichtlinien selbst als auch die durchsetzenden Komponenten müssen einfach verwaltet werden können. Im IND²UCE Privacy Service werden daher die relevanten Sicherheitsrichtlinien spezifiziert und verwaltet. Dazu bietet IND²UCE mehrere Möglichkeiten. Ein Experten-Editor zur Spezifikation von technischen Sicherheitsrichtlinien in der IND²UCE Policy Sprache unterstützt den Benutzer bei der Formulierung seiner gewünschten Datennutzungsbeschränkungen. Für Endanwender können maßgeschneiderte und leicht verständliche Spezifikationsschnittstellen zur Einstellung der individuellen Sicherheitsbedürfnisse der jeweiligen Anwendergruppe generiert werden. Diese ermöglichen dem Benutzer eine Spezifikation in natürlicher Sprache und transformieren die getätigten Einstellungen in die maschinenlesbare IND²UCE Policy Sprache. Verschiedene Arten von Schnittstellen (z. B. ein Wizard, Sicherheitsstufen zur Auswahl, Konfiguration mittels Textschablonen) werden angeboten. Diese wurden für verschiedene Arten von Nutzern evaluiert, um Schnittstellen zu bieten, die schnell, einfach und insbesondere korrekt spezifizierte Sicherheitsrichtlinien ermöglichen. Der IND²UCE Privacy Service ist ein Web-basierter Dienst, welcher hochskalierbar in der Cloud betrieben werden kann.

Policy Enforcement: IND²UCE bietet ein Open-Source Software Development Kit (SDK), das alle Komponenten zur Durchsetzung von Sicherheitsrichtlinien in der eigenen Java-Anwendung beinhaltet. Mit diesen Komponenten werden Datenflüsse kontrolliert, sicherheitsrelevante Aktionen in der Software angestoßen und Informationen für zuverlässige Sicherheitsentscheidungen bereitgestellt. Insbesondere können einzelne Datennutzungen gemäß den Sicherheitsrichtlinien durchgesetzt werden. Der Privacy Service, der zusätzlich als Entscheidungskomponente dient, gleicht jede Datennutzung mit den aktiven, vom Anwender konfigurierten Sicherheitsrichtlinien ab und fällt eine Entscheidung für die Nutzung. Mit dieser Entscheidung wissen die in die eigene Software integrierten Komponenten des SDKs, was sie im Einzelfall zu tun haben: den Zugriff freigeben, verbieten, oder unter Auflagen (und ggf. in modifizierter Form) gestatten.

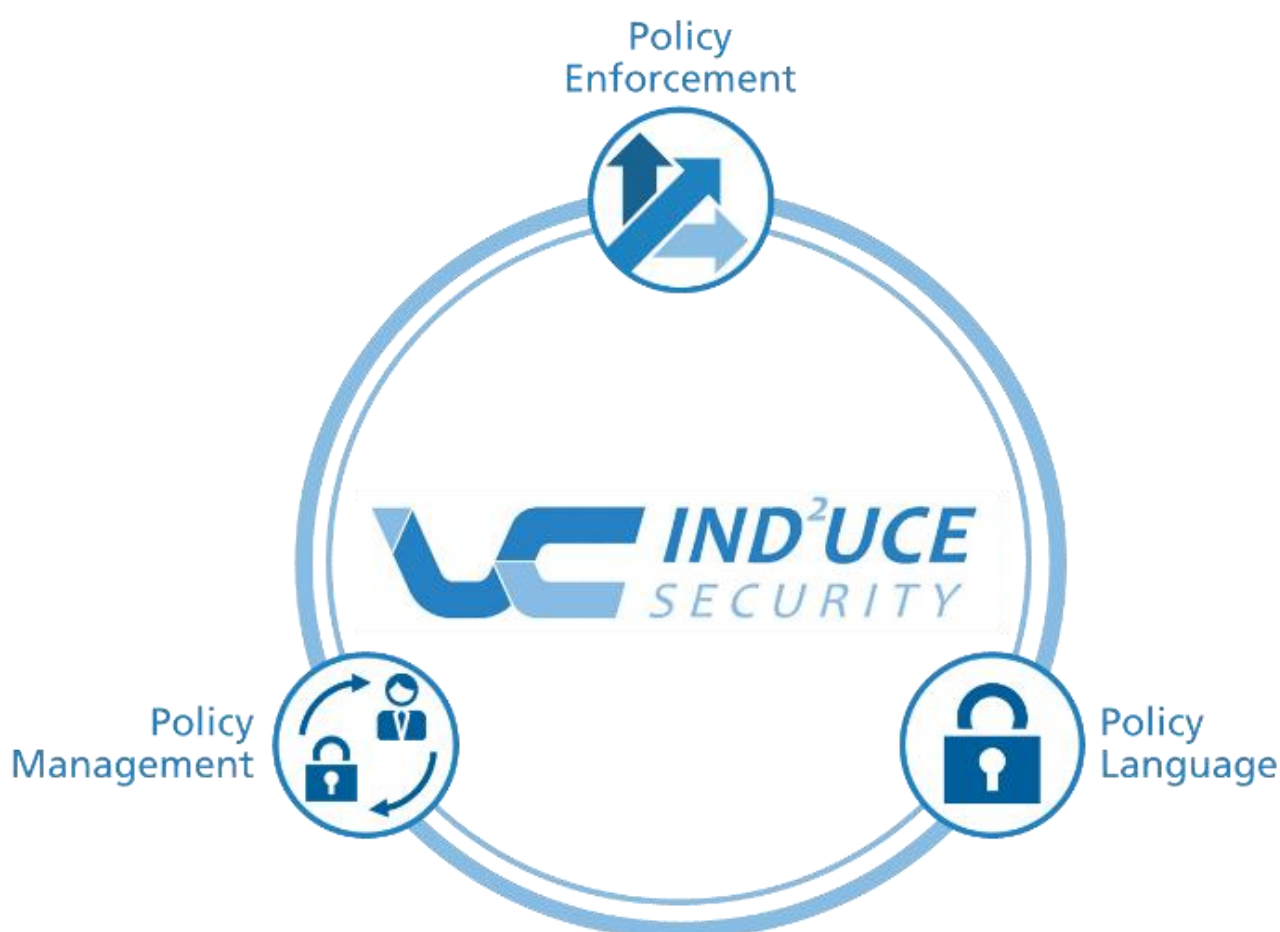


Abbildung 5: Bausteine von IND²UCE (Integrated Distributed Data Usage Control Enforcement)

IND²UCE kann in verschiedenste Systeme integriert werden. Das Java SDK ermöglicht Entwicklern eine schnelle und unkomplizierte Integration mit wenigen Zeilen Code pro Kontrollpunkt in bestehende Java Anwendungen. Wird zudem das Spring-Framework eingesetzt, verringert sich der Integrationsaufwand auf wenige Annotationen und eine Zeile Code für die Durchsetzung der Sicherheitsrichtlinien im Kontrollpunkt. Für andere Entwicklungsumgebungen bietet IND²UCE REST-Schnittstellen an, gegen welche programmiert werden kann. IND²UCE hat geringe Auswirkungen auf die Zielanwendung, diese hängen von den spezifizierten Sicherheitsrichtlinien ab. Bei der Integration muss beachtet werden, dass ein von IND²UCE verhinderter Datenfluss nicht beim

Empfänger ankommt. Die Policy-Entscheidungen sind sehr performant, sodass sich die Verzögerung in der kontrollierten Datenkommunikation quasi auf die zusätzliche Netzwerklatenz für die Kommunikation mit dem Privacy Service beschränkt. Weitere Informationen zu IND²UCE sind auf www.ind2uce.de verfügbar. Eine Entwicklerdokumentation findet sich auf dev.ind2uce.de.

Virtualisierung von Industrieanwendungen (Fraunhofer AISEC, TU München)

Der Lösungsbaustein ermöglicht es ein System On-The-Fly (während des laufenden Betriebs ohne Unterbrechung) in eine virtuelle Maschine zu konvertieren. Eine virtuelle Maschine (VM) simuliert ein vollständiges und abgekapseltes Computersystem das auf einem Wirtssystem (Host) ausgeführt wird. Der Fokus liegt hier auf eingebetteten Intel und ARM basierenden Systemen, die das Linux Betriebssystem einsetzen, da diese Kombination im industriellen Bereich eine dominante Stellung innehat.

Ziel dieses Lösungsbausteins ist die Analyse von vermeintlich befallenen Systemen und das Abschotten und Überwachen von kritischer Infrastruktur. Hierfür bietet das System Schnittstellen zur Systemanalyse und -überwachung an, die vom Nutzer zur leichten Handhabung genutzt werden können. Durch den Einsatz können gezielte Angriffe frühzeitig erkannt und analysiert werden um die Sicherheit des Systems langfristig zu steigern.

Der Einsatz des Bausteins erfordert ausreichenden Zugriff auf Hard- und Software des zu schützenden Systems, im Optimalfall setzt man hier auf offene Standards. Die Implementierung sollte im besten Fall direkt durch den Hersteller des Systems erfolgen; kann durch offene Standards aber auch durch einen erfahrenen Partner selbst durchgeführt werden.

Weiterführende Informationen können in der wissenschaftlichen Publikation (Sergej Proskurin, 2018) nachgelesen werden.

Der Einsatz des Lösungsbausteins erfordert ein eingebettetes System, das über ausreichende dimensionierte Hardwareressourcen verfügt. Dies ist dringend notwendig um den durch die Virtualisierung entstehenden Overhead abzufangen und das Leistungsniveau der virtualisierten Software zu gewährleisten.

Die Integration des Bausteins erfolgt im besten Fall bereits bei der Entwicklung des Systems. Der Hersteller kann somit dem Endkunden die Schnittstellen direkt zur eigenen Verwendung anbieten. Dies erfordert entsprechendes Fachpersonal beim Hersteller bzw. beim ausführenden Betrieb.

Laufende Anwendungen werden von der durchgeführten Analyse nicht beeinflusst. Hierdurch kann die Schadsoftware die laufende Überwachung nicht erkennen und somit ihr Verhalten nicht anpassen. Zusätzlich erhält der Analyst einen tieferen Einblick in das System und kann gegebenenfalls schneller und gezielter auf Angriffe oder etwaige Systemfehler reagieren.

Ein möglicher Nachteil ist der höhere Aufwand bei der Entwicklung, dieser kann allerdings begrenzt werden, wenn die Lösung von Anfang an als Systembaustein in Betracht gezogen wird. Skaleneffekte treten allerdings früh ein, da der Lösungsbaustein nach initialem Aufwand für mehrere Produkte eingesetzt werden kann.

Mit diesem Lösungsbaustein können des Weiteren Schwachstellen in industriellen Komponenten frühzeitig identifiziert und geschlossen werden. Hierfür bieten die Entwicklungen der Industrie 4.0 die Möglichkeit, detaillierte Untersuchungen bereits im Vorfeld zur Markteinführung industrieller Fertigungskomponenten durchzuführen. Dies ist erforderlich, da die Kosten für die Beseitigung von

Schwachstellen nach der Markteinführung erheblich höher sind, als dies bei der Entwicklung bzw. Pilotierung der Fall ist.

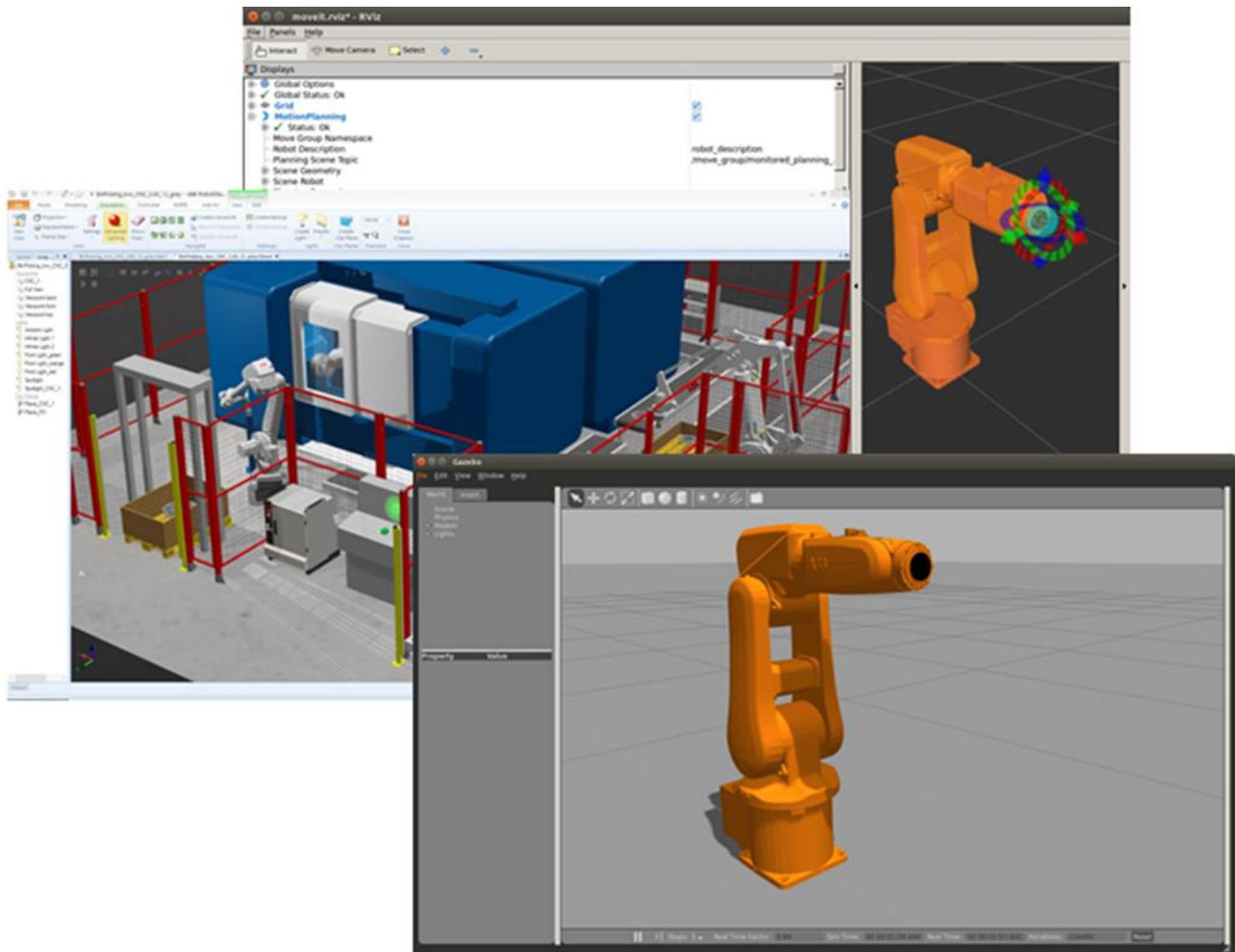


Abbildung 6: Modellierung und Simulation von virtuellen Automatisierungskomponenten als Ausgangspunkt für Securitysimulationen

Soll eine neue Anlage in Betrieb genommen werden, besteht diese aus einer Vielzahl von vorhandenen bzw. auch neuen Komponenten. Integrationstests sind durch die Komplexität der Bestandteile schwierig in der Praxis durchzuführen. Die computergestützte Entwicklung erlaubt hier eine effizientere Durchführung von Tests mittels virtueller Inbetriebnahme. Dadurch wird eine größere Anzahl von Testfällen praktikabel durchführ- und auswertbar.

In der vernetzten Produktion gewinnt die IT Sicherheit zunehmend an Bedeutung, wird aber bei vielen Produktentwicklungszyklen für Industriekomponenten nur nachrangig betrachtet. Der vorgestellte Lösungsbaustein beschäftigt sich mit der Ein- und Durchführung von IT Sicherheitstest an virtuellen Komponenten bei der Produktentwicklung. Dazu wird die bereits durchgeführte virtuelle Inbetriebnahme um Analysen im Bereich der IT Sicherheit erweitert.

Virtuelle Inbetriebnahme kann dazu benutzt werden, um Komponenten in Fällen zu überprüfen, welche basierend auf realen Anwendungsfällen modelliert sind.

Dazu sind die entsprechenden Modelle der industriellen Komponenten erforderlich. Diese lassen sich in simulierten Umgebungen zu Fertigungsstraßen kombinieren. Anschließend können Anwendungsprogramme auf diese virtuellen Fabrik Instanzen ausgewertet werden.

Durch die Virtualisierung lassen sich eine Vielzahl von Konfigurationen durch automatisierte Prozesse analysieren. So hilft dieser Lösungsbaustein während der Entwicklungsschritte mögliche Schwachstellen zu identifizieren und zeitnah zu beheben.

Dieses Verfahren hilft Schwachstellen in industriellen Komponenten, deren Implementierung sowie in der Logik von Anwendungsprogrammen zu identifizieren. Der Lösungsbaustein lässt sich kostengünstig in die bestehenden Entwicklungsprozesse integrieren und trägt nachhaltig zur Entwicklung und Herstellung sicherer industrieller Komponenten bei.

Angriffserkennung und Absicherung der Feldbuskommunikation (Fraunhofer AISEC)

Nahezu alle Feldbusprotokolle, wie sie in heutigen Industrieanlagen verwendet werden, sind ohne IT-Sicherheitsmaßnahmen entworfen worden. Durch die steigende Vernetzung bildet sichere Kommunikation jedoch einen wichtigen Grundpfeiler für die IT-Sicherheit der Industrie 4.0.

In IUNO wurden deshalb Bausteine für eine effiziente und praxistaugliche Angriffserkennung auf der Netzwerk- und Feldbuskommunikation erarbeitet. Bisherige Methoden haben sich auf die Erkennung von Angriffen in bestimmten, ausgewählten Netzwerk- oder Feldbusprotokollen beschränkt. Dadurch sind diese in der Lage sehr spezifische Analysen durchzuführen, um Angriffe zu erkennen. Im Rahmen des IUNO-Projektes hat sich allerdings gezeigt, dass in den meisten industriellen Wertschöpfungsnetzwerken eine Vielzahl heterogener Protokolle verwendet wird. Die Beschränkung auf einzelne Protokolle ist daher insbesondere im Rahmen der vierten industriellen Revolution mit steigender horizontaler und vertikaler Vernetzung nicht ausreichend (Giehl & Schneider, 2018). Gleichzeitig steigt hierdurch auch der Umfang an zu untersuchenden Daten.

Daher wurden Methoden zur effizienten Aufzeichnung dieser Daten erarbeitet, um diese für Analysesysteme bereitstellen zu können (Hansch, Schneider, & Plaga, 2017). Hierbei wurde ein effizientes und gleichzeitig effektives Verfahren entwickelt, das industriellen Netzwerkverkehr direkt während der Übertragung reduzieren kann. Die charakteristischen Eigenschaften dieses Datenverkehrs werden ausgenutzt und sich wiederholende Sequenzen durch wesentlich kürzere IDs ersetzt. Da die gesamte Automatisierungstechnik zum Ziel hat, sich wiederholende Vorgänge zu vereinfachen, lassen sich solche Wiederholungen auch in der Kommunikation wiederfinden und entsprechend herausfiltern.

Des Weiteren hat das Fraunhofer AISEC ein Framework zur Analyse von rohen Byteströmen erarbeitet, das die Erkennung von Angriffen unabhängig der verwendeten Feldbusprotokolle ermöglicht. Durch die Verwendung von neuronalen Netzen ist es möglich, ein Abbild des Normalverhaltens von industriellen Netzwerken zu bekommen, ohne dafür Informationen über die verwendeten Protokolle oder darin kommunizierten Inhalte zu benötigen. Durch eine Komprimierung der untersuchten Daten kann ein Angriff durch eine Abweichung in der Komprimierungsrate detektiert werden.

Eine weitere Möglichkeit Angriffe und Anomalien zu erkennen, besteht darin, Veränderungen der physikalischen Signallaufzeiten zu überwachen. Mit einem Testaufbau wurde hierbei festgestellt, dass eine solche Überwachung bereits mit Bordmitteln aktueller Betriebssysteme möglich ist. Das

The diagram illustrates the Remote Maintenance Platform (RMP) Architecture, showing the interaction between a Remote Office, a Client (Smartphone), a Server, and the Remote Maintenance Platform itself.

Remote Office: Contains a Remote Maintenance Technician.

Client (Smartphone): Interacts with the Server and the Remote Maintenance Platform.

Server: Acts as the central hub for authentication and communication.

Remote Maintenance Platform: Includes components like PKI, Ticketing, QR-Authenticator, and Routing.

Key Processes and Channels:

- 1st Factor Authentication:** Involves the Client and Server using a pairing key (K_p).
- QR-Code Reception:** The Client receives a QR code from the Server, which contains QR elements (C_s, ID_s, T).
- Smartphone:** The Client's interface for receiving and processing the QR code.
- Elements of OTP-A Generation - Proof of Established Payload Channel:** The Client generates OTP-S' and OTP-S, which are sent to the Server.
- Payload Channel:** A green channel used for secure communication between the Client and the Server.
- Out-of-Band Channel:** A blue dashed channel used for secure communication between the Client and the Remote Maintenance Platform.
- Secure Connection to Production Network:** The final outcome of the RMP process.

Um den vorhandenen Schwachstellen entgegenzuwirken, wurden zudem aktuelle Angriffsmethoden auf die durch die Feldbusse vernetzten Plattformen studiert. Eine Analyse des medienwirksamen Rowhammer-Angriffs hat gezeigt, dass auch Industrieanlagen durch solche Angriffe gefährdet sind (Wiedermann & Plaga, 2018). Jeder erfolgreiche Angriff lässt dabei am Ende meist vielfältige Manipulationsmöglichkeiten hinzu. Während der Analyse der Angriffsindikatoren, hat sich durch Analyse der Anwendungsszenarien des IUNO-Konsortiums herausgestellt, dass hierbei besonders auf eine vertrauliche und insbesondere authentifizierte Kommunikation Wert gelegt wird. Diese Anforderung wird wie folgt adressiert:

Gerade die Erkenntnisse der Rowhammer Analysen zeigten, dass speziell die kryptografischen Schlüssel im Praxiseinsatz nicht zu schützen sind und daher im besonderen Fokus von Angreifern stehen. Hier wurden im Rahmen von IUNO Schutzbausteine untersucht und Ihre Anwendbarkeit für den industriellen Einsatz bewertet (Plaga, Wiedermann, Hansch, & Newe, June 2018).

19

Automatische Firmware-Analyse / Malwareanalyse (TU München)

Der Lösungsbaustein ist mehrstufig: In erster Instanz wird eine Sammlung von Firmware Images automatisch angelegt indem ein spezielles Programm (Webcrawler) bekannte Herstellerseiten nach Downloads durchsucht, um diese später zu klassifizieren. Im nächsten Schritt werden die gesammelten Dateien entweder als Firmware Images oder sonstige Dateien klassifiziert. Die Firmware Images werden nun durch ein von uns trainiertes Maschine Learning Modell (MLM) einem Hersteller zugeordnet.

Die Dateien werden dann automatisiert entpackt und das eingebettete Webinterface wird extrahiert. Anschließend wird das extrahierte Interface emuliert um von dem nach außen hin zugänglichen Interface einen Fingerabdruck zu erstellen.

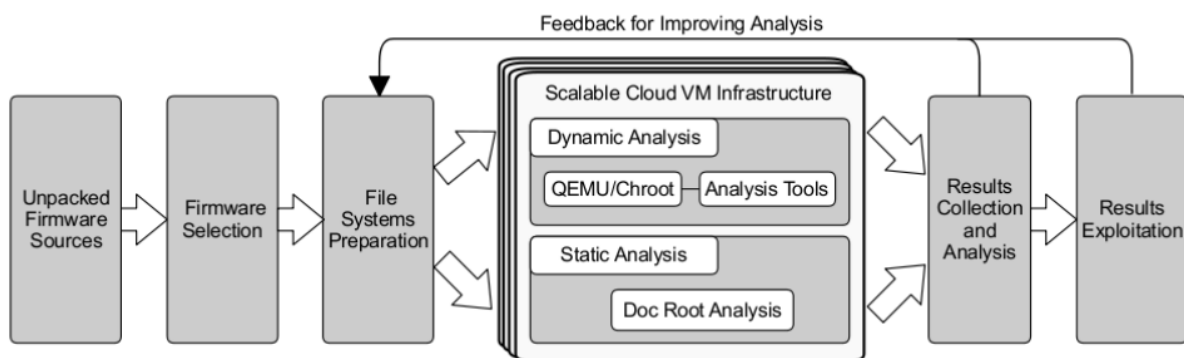


Abbildung 8: Architektur der Firmware-Extraktion und -Analyse

Diese Informationen fließen zusammen mit den Erkenntnissen des ersten Maschine Learning Modells in eine aggregierte Datenbank ein, mit dem ein weiteres Maschine Learning Model trainiert wird, das verschiedene Anwendungszwecke hat.

Der erste Anwendungsfall stellt die Sicht des Netzwerkadministrators da: Er kann nun ein Netzwerk automatisch nach Webinterfacen durchsuchen, diese mittels des ML Modells zuordnen und direkt sehen, ob es bekannte Sicherheitslücken für dieses Gerät gibt.

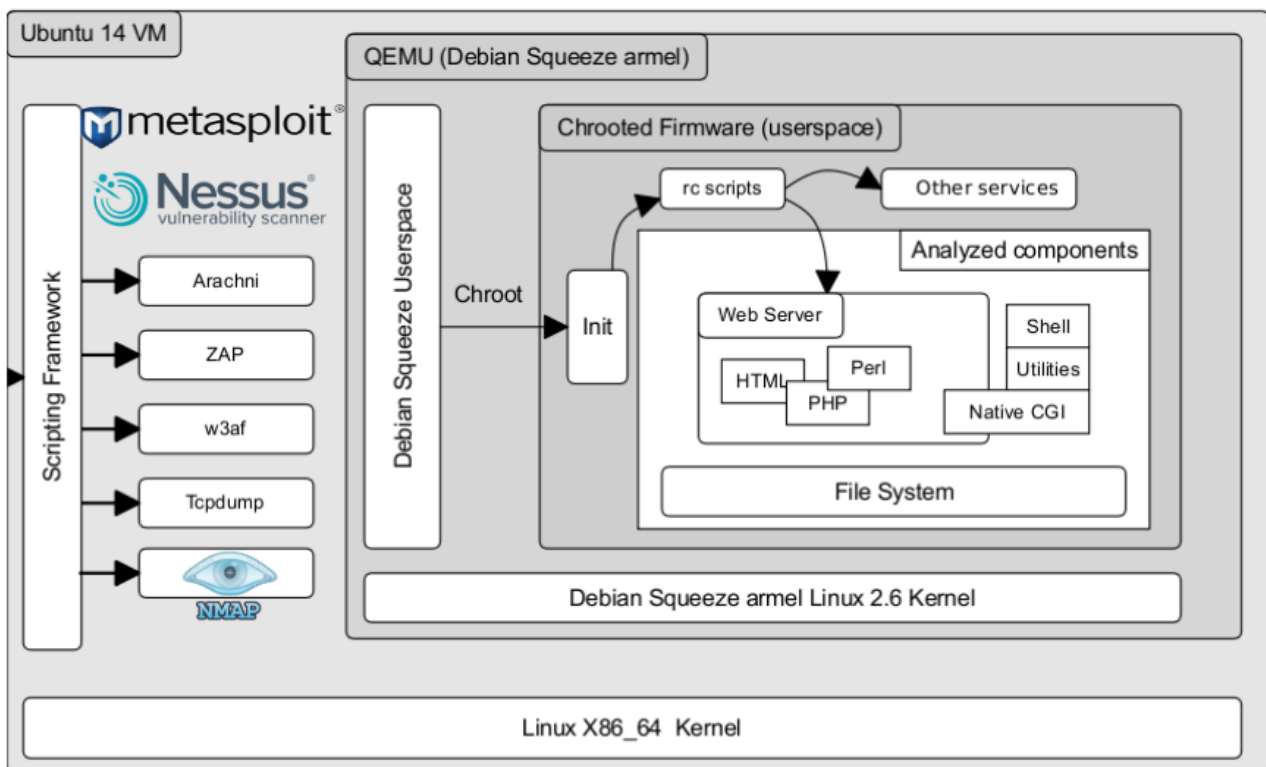


Abbildung 9: Architektur der Webinterface Emulation (Firmware- und Malwareanalyse)

Der zweite Anwendungsfall ist durch einen Sicherheitsanalysten gegeben, der das zu analysierende Netzwerk ebenfalls abscannt, nun aber die gefundenen verwundbaren Geräte durch automatisierte Tools angreift um deren Verwundbarkeit zu demonstrieren. Diese Ergebnisse können dann dem Kunden zur weiteren Bearbeitung übergeben werden.

Die Voraussetzungen zur Inbetriebnahme dieses Lösungsbausteins sind vergleichsweise gering. Es wird lediglich entsprechende Hardware für den Maschine Learning Prozess vorausgesetzt, die genutzt werden kann, um die Modelle zu trainieren. Daraufhin kann das Firmennetzwerk beliebig nach Schwachstellen durchsucht werden.

Der zeitaufwändigste Schritt ist das sammeln und kategorisieren der Firmware Images, dies kann jedoch auch zentral erfolgen, um kooperativ von dieser Arbeit zu profitieren.

Durch diesen Lösungsbaustein kann ein Netzwerk automatisch abgesichert werden und immer auf dem neusten Stand gehalten werden. Dies unterstützt vor allem Netzwerkadministratoren und gibt somit mehr Zeit für andere Aufgaben frei.

Der initiale Aufwand ist mit höheren Personalkosten verbunden, kann aber durch Kooperation abgemildert werden.

Schlüsselerzeugung aus Funkkanal (DFKI)

Das Konzept der *Physical Layer Security (PhySec)* beschreibt allgemein eine Reihe technischer Verfahren, bei denen die Generierung von kryptographischem Schlüsselmaterial, basierend auf unterschiedlichen physikalischen Eigenschaften, beruht. Das hier konkret behandelte Verfahren zur *Secret Key Generation (SKG)* verwendet charakteristische Eigenschaften eines Funkkanals zur

Erzeugung von symmetrischen, kryptographischen Schlüsseln. Ein Funkkanal wird stark, durch von der Umgebung abhängige Faktoren, beeinflusst. Diese sogenannte Mehrwegeausbreitung bei Funksignalen entsteht beispielsweise durch Beugungen, Reflexionen, Brechung oder Überlagerungen des Signals. Dabei sind diese Einflüsse auf den Funkkanal für beide Seiten ähnlich, was für eine Schlüsselerzeugung verwendet werden kann. Mit dem angesprochenen SKG Verfahren wird zwischen zwei am Kommunikationsprozess teilnehmenden Entitäten ein symmetrischer Schlüssel generiert. Vor allem in Bereich der *Low Energie Devices* im (*industrial*) *Internet-of-Things (IIoT)* wächst der Bedarf an ressourcenschonenden kryptographischen Verfahren. Das Ziel dieses Lösungsbausteins liegt auf ebendieser energieeffizienten Schlüsselerzeugung sowie des Schlüsselaustausches zwischen den Entitäten. Damit die SKG angewandt werden kann, müssen die entsprechenden Entitäten über einen drahtlosen Verbindungsweg miteinander kommunizieren können. Es ist dafür notwendig diejenigen Entitäten innerhalb eines Systems zu kennen, welche diese Anforderung erfüllen. Über das Gesamtsystem als solches, sind keine weiteren Kenntnisse nötig.

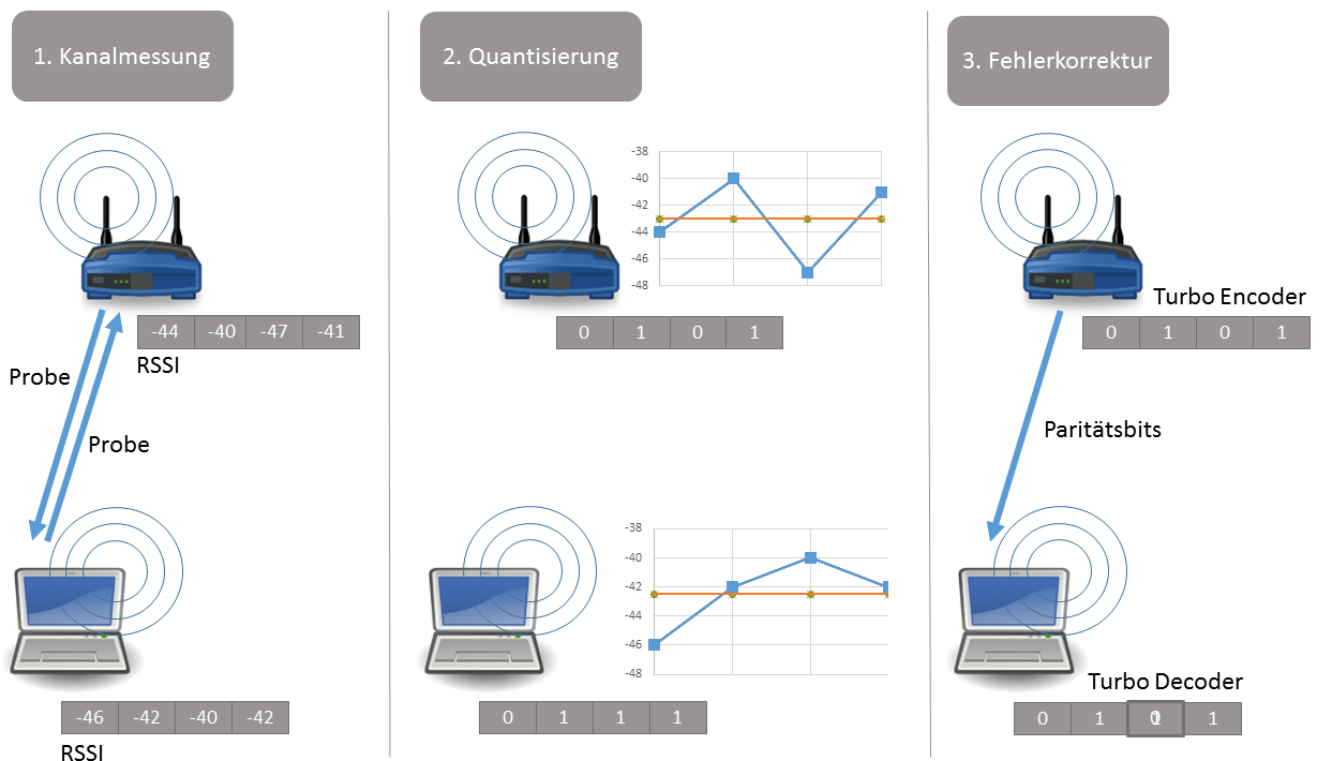


Abbildung 10: Schlüsselerzeugung aus Funkkanal

Das Konzept kann in alle bestehenden Systemkomponenten welche über ein geeignetes Funkmodul verfügen integriert werden. Eine nachträgliche Umrüstung bzw. Erweiterung mit einem Funkmodul ist ebenfalls möglich. Das Konzept als solches ist eine reine Softwarelösung und Plattformunabhängig verwendbar. Aufgrund des Prinzips der Kanalreziprozität, kann angenommen werden das der Funkkanal für zwei miteinander kommunizierende Entitäten nahezu identisch ist. Für das vorgestellte Verfahren ist es unerheblich welcher der beiden Entitäten die Rolle des *Master* und welche die des *Slave* einnimmt.

Der Lösungsansatz wird ausführlich in den Veröffentlichungen der DFKI erläutert. Darüber hinaus kann eine Internetrecherche zu dem Themengebiet der *Physical Layer Security* grundlegende Fragen zu dem allgemeinen Funktionsprinzip beantworten. In entsprechender Fachliteratur können die standardmäßig verwendeten Algorithmen zu Kanalmessung, Fehlerkorrektur oder *Privacy Amplification* nachgeschlagen werden. Für die Anwendung des Verfahrens ist es zwingend erforderlich, dass die beteiligten Entitäten über drahtlos Module miteinander kommunizieren können. Falls solche Module nicht initial vorhanden sind, können diese problemlos nachgerüstet werden. Die Verfahren der *Physical Layer Security* mit der *Secret Key Generation* können dazu beitragen, kryptographische Prozesse auf *IoT-Devices* einzusetzen. Dadurch können die übertragenen Daten verschlüsselt werden.

Durch den Schlüsseltausch und die Möglichkeit der verschlüsselten Kommunikation kann ein bestimmtes Vertrauensniveau erreicht werden. Das vom DFKI vorgestellte Verfahren befindet sich noch nicht in einem marktreifen Status. Das Verfahren erfordert einen gewissen Konfigurationsaufwand, welcher für Laien nicht zu leisten ist. Für eine optimale Funktionsweise des Verfahrens wird eine hohe Entropie im Funkkanal benötigt. Dafür ist ein bestimmtes Maß an Störeinflüssen und beeinflussenden Faktoren (Beugung, Streuung, Abschattung) notwendig. Die Verwendung von Methoden der SKG ermöglicht es kryptographisches Material auf *IoT-Devices* zu implementieren. Das trägt dazu bei, das *Intellectual Property* durch verschlüsselte Übertragung zu schützen. Auf weitere Systemkomponenten oder andere Sicherheitsmodule hat der Lösungsbaustein keinen Einfluss. Er kann als autonome Lösung verwendet werden. Falls es gewünscht ist und sinnvoll ist, können die generierten Schlüssel jedoch auch für weitere kryptographische Anwendungen verwendet werden. Der Nachteil des Verfahrens ist die bisher nicht vorhandene Marktreife und die nicht ganz triviale Konfiguration des Systems. Entsprechend des verwendeten Funkstandards existieren unterschiedliche Stellschrauben, welche eine bestimmte Fachkompetenz bei der Auswahl der Algorithmen bedarf. Der Input in das System sind die Eigenschaften des Funkkanals, welche bei der Kanalmessung /-schätzung entstehen. Nach dem durchlaufen verschiedener Verarbeitungsblöcke entsteht ein kryptographischer Schlüssel, welcher der Output des Lösungsbausteins darstellt. Der Einsatzbereich ist unabhängig von der Größe der Organisationseinheit. Da der Schlüsseltausch und die Schlüsselerzeugung immer nur zwischen zwei beteiligten Entitäten erfolgt, kann dieser auch in kleineren Einheiten verwendet werden. Mit einer zunehmenden Anzahl an Kommunikationsteilnehmern, Entitäten mit welchen eine Entität kommuniziert, steigt der Aufwand für das Schlüsselmanagement.

Isolationsmaßnahmen (TU München)

Die Isolation von verschiedenen Komponenten, sei es Hard- oder Software, ist ein tragendes Konzept der IT-Sicherheit. Ein gängiges Verfahren hierfür ist eine sogenannte virtuelle Maschine (VM), bei der ein virtuelles Gastsystem auf einem real existierenden Wirtssystem aufgesetzt wird. Dieses Vorgehen ist allerdings relativ hardwareintensiv, da jede VM dedizierte Ressourcen benötigt. Besonders im Bereich der eingebetteten Systeme ist der Mangel an Ressourcen ein Hindernis beim potentiellen Einsatz von Virtualisierung.

Unser Lösungsbaustein greift hier ein und ermöglicht es die teure Virtualisierung durch günstigere Containerlösungen zu ersetzen, bei denen ein abgeschotteter Bereich für jede Anwendung bereitgestellt wird.

Wir lösen hiermit ein grundsätzliches Problem der Isolationsmechanismen: Die Abschottung nach außen. Gerade eingebettete Systeme verfügen über viel Konnektivität und haben als Hauptaufgabe die Interaktion mit anderen Akteuren wie zum Beispiel Sensoren oder Ansteuerungen.

In unserem Lösungsbaustein skizzieren wir eine mögliche Architektur für den Einsatz von Containerlösungen, die isoliert sind, aber trotzdem mit anderen interagieren können.

Bisherige Anwendungen lassen sich einfach in einzelne Container aufteilen und können dort wie gehabt ausgeführt werden. Dies kann durch Hersteller der Systeme oder versierte Administratoren im Betrieb geschehen.

Zur Validierung wurde ein Versuchsaufbau geschaffen, der ein eingebettetes System simuliert, das seine Software in einer Containerlösung ausführt und dabei trotzdem vollen Zugriff auf ein via Hardware an das System angeschlossenes Trusted Plattform Modul (TPM) besitzt. Hierfür wurde ein speziell für IUNO entwickeltes TPM 2.0 Modul genutzt. Der Zugriff auf das TPM ermöglicht einen sicheren Umgang mit Schlüsselmaterial im Container und bietet die Möglichkeit den Zustand des Systems von außen zu attestieren (Remote Attestation).

Remote-Attestierung bietet die Möglichkeit, dass ein System gegenüber einer autorisierten Partei nachweisen kann, dass weder seine Software noch seine Hardware unerlaubt modifiziert wurden. Dadurch kann sichergestellt werden, dass alle Sicherheitsaktualisierungen für das geprüfte System eingespielt wurden. Dies ermöglicht jedem System ein Vertrauenslevel zuzuordnen. Innerhalb von Industrie 4.0 spielt Remote-Attestierung eine entscheidende Rolle.

Grundsätzlich wird keine spezielle Hardware benötigt. Da Containerlösungen einen vernachlässigbaren Overhead verursachen und rein in Software umgesetzt sind kann existierende Hardware weiter genutzt werden.

Um diesen Lösungsbaustein aktiv zu nutzen müssen sich Administratoren oder Entwickler mit Containerlösungen vertraut machen. Diese sind allerdings bereits im Serverumfeld weit verbreitet und viele Entwickler sind bereits mit Containern vertraut.

Dienste und Anwendungen profitieren somit von einer erhöhten Sicherheit, da eine kompromittierte Anwendung ihren Container nicht verlassen kann. Gleichzeitig können die Dienste aber auch wie gewohnt betrieben werden und müssen nicht auf den Container angepasst werden. Somit können auch reguläre Instanzen neben Container Instanzen betrieben werden.

Zusätzlich kann die demonstrierte Integration eines TPM genutzt werden um durch Remote-Attestierung das Sicherheitsniveau nach außen nochmals zu erhöhen und den Softwarestand innerhalb des Containers zu garantieren.

Softwareschutz und -lizenzierung (WIBU Systems AG)

Auf dem Einsatz des Secure Elements (SE), hier in der Repräsentation des TPMs als sicherem Schlüsselspeicher und Vertrauensanker, sind die erforderlichen Werkzeuge (die elementaren Tools) zwecks einer breiten Anwendung für Software- und Datenschutz im Einsatz für kleinere Embedded Systems entwickelt und weiterentwickelt worden. Abgesehen von der langjährigen Verfügbarkeit des eigenen CodeMeter SE steht der TPM als Trust Anchor für künftige Embedded Systems im industriellen Bereich.

Die elementaren Tools, - und dazu gehören auch in diesem Kontext die webbasierten Services-und Integrationshilfen wie Treibersoftware, erstrecken sich auf die Anwendung von Schutzmechanismen

auf Software und Daten. Zum Schutz des Know-hows in der Software wird die ausführbare Anwendung vor der Auslieferung an ein Embedded System Plattform verschlüsselt. Die Zielpattform ist ein Embedded Linux-System basierend auf ARM-Hardwarearchitektur ausgestattet mit einem eingebettetem TPM oder auch mit einem vergleichbaren SE vorgesehen als Vertrauensanker für die zur Anwendung kommenden Schutztools und Integrationshilfen. Der TPM-Vertrauensanker unterstützt mit einem kryptographischen Verfahren die Einrichtung eines TPM-gebundenen, softwarebasierten Lizenzcontainers, der als Lizenz- und Schlüsselspeicher für geschützte Anwendungen und Daten dient.

Mit Hilfe des Schutztools AxProtector (SDK Software Development Kit) kann die gesamte Anwendung komplett oder auch nur einzelne Funktionen mit unterschiedlichen Schlüsseln verschlüsselt werden, die mithilfe einer Lizenz in einem etablierten Lizenzcontainer des Zielsystems gespeichert werden. An alle zur Ausführung der Anwendung autorisierten Systeme wird dieselbe geschützte Softwareanwendung übertragen und bei Vorhandensein der Berechtigungsparameter wie Zählerstände oder Nutzungsdauer sowie der geräteindividuellen Schlüssel auch aktiviert. Nur die Nutzung der freigeschalteten Funktionen wird erlaubt.

Eine graphische Benutzeroberfläche, wie unten auszugsweise aus dem AxProtector API-Guide dargestellt, erlaubt die wahlweise Anwendung sowohl von CodeMeter-Hardware basierten Lizenzcontainern als auch von CmAct Lizenzcontainern, die den TPM als SE-Vertrauensanker zur Systembindung einer CmAct-Datei verwenden.

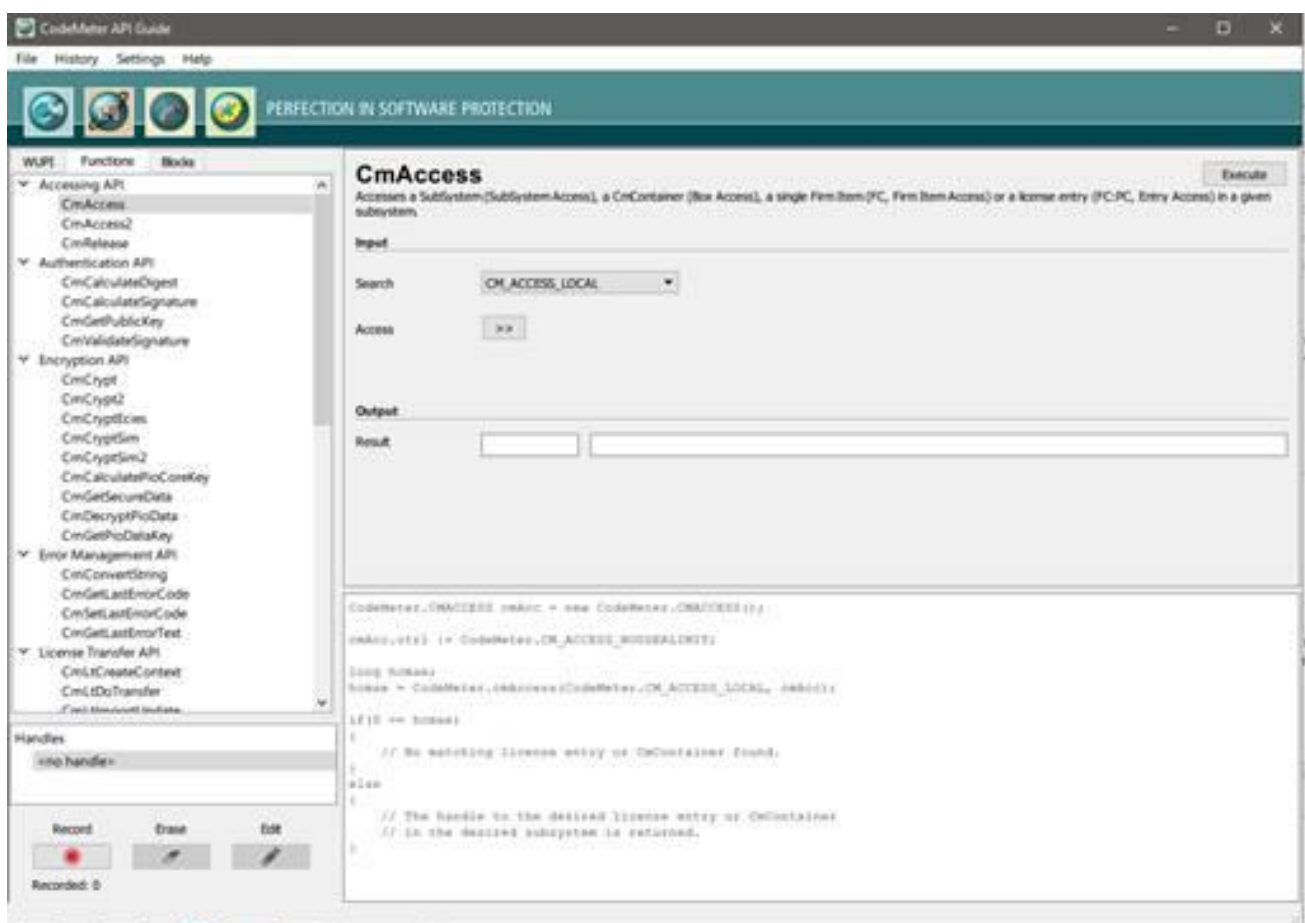


Abbildung 11: Beispiel für ein AxProtector-Anwendungsmenu für die individuelle Anwendung des CodeMeter Crypto-APIs, hier Access-Methoden zum Lizenzcontainer

Gleichermaßen wie der automatisierte Schutz von Software den ausführbaren Code durch ein einen Wrapper abkapselt, können auch Dateien verschlüsselt und an eine Lizenz gebunden werden. Ein automatisierter Schutzvorgang kann durch den Einsatz des AxProtectors erfolgen oder alternativ durch eine Anwendung für Datenver- und -entschlüsselung, die auf der individuellen Anwendung des Crypto-API mit seinen einzubettenden CodeMeter-Libraries aufsetzt. Die Weiterentwicklung der Softwarearchitektur AxProtector und des CodeMeter Runtimesystems konzipiert und ausgeführt wurde, dass die Schutz- und Lizenzierungsmechanismen auf Entwicklerebene sowohl für Embedded Systems als auch für Windows-Betriebssysteme angewendet werden können. Durch Hinzufügen von unterstützenden Integrationshilfen in Form von Libraries für kleinere Embedded Systems, wie zum Beispiel Raspberry-Pi und H/W-Entwicklergemeinde konnte der Einsatzbereich des AxProtectors für industrielle Anwendungen in Bezug auf die Unterstützung von ARM-Prozessorarchitekturen ausgedehnt und funktionell erweitert werden.

Als weiteres Tool dient das Lizenzmanagementsystem CodeMeter License Central zur Generierung und Verwaltung von Lizenzen auf den angeschlossenen Zielsystemen, die in einem Netzwerk einer Organisation zu einer Security-Anwendung zusammengefasst sind. Die Lizenz kann lokal limitiert für ein einzelnes Gerät als auch für im Netzwerk verbundene Geräte als Netzwerklizenz erstellt werden. Die Lizenzen können im einem Industrienetzwerk über die zentralen Managementfunktionen aktiviert und de-aktiviert werden. Über Konnektoren für Datenbanken und Gateways für Webservices können Lizenzteilnehmer, die z.B. in einem Shopfloor gemeinsam den Produktionsbetrieb, angefangen von Update-Dienstleistungen eines Komponentenlieferanten bis hin zur MES- und ERP-Anbindung von Lieferanten und Hersteller im Produktionsprozess, in einem Lizenzmanagementsystem der verbundenen Parteien in einer gemeinsamen Wertschöpfungskette zusammengefasst werden.

Durch Einführen von automatisierenden Funktionen im Lifecycle-Management von Lizenzgenerierung, Lizenz-Update und -Übertragung (Auto-Update) wurde dem Entwicklungsziel entsprochen, in zu erwartenden IoT-Anwendungen für große Gerätepopulationen mit Embedded System Security und den daraus zu erwartenden Ansprüchen nach hoher Kapazität für Aktivierungs- und Deaktivierungsprozesse in industriellen Netzwerken.

Dazu wurde das Lizenzportal bereitgestellt, um die Container-Typen CmAct für die Container-Bindung und damit die Anwendung von TPMs als Vertrauensanker in industriellen Steuerungssystemen zu nutzen. Gateway-Anwendungen auf den Embedded Systems unterstützen den automatisierten Webzugang zum Portal durch einen internen Software Activation Wizard, der auf den Embedded Systems durch Lifecycle Management Prozesse automatisch angestoßen wird.

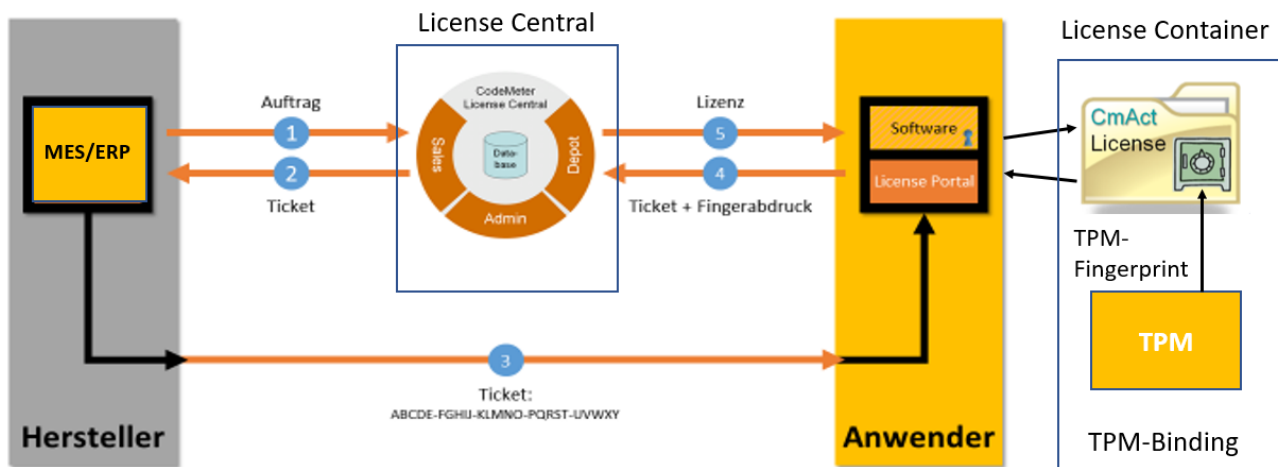


Abbildung 12: Schematische Darstellung Abläufe Lizenzmanagement für softwarebasierten Lizenzcontainer mit Bindung an TPM, die Rolle von Hersteller (Betreiber) und Anwender (Gerät) beim Ausrollen von Lizenzen in Lizenzcontainer

Der schematische Ablauf einer Lizenzerstellung ist in Abbildung 12 zu sehen: (1) Auftragserteilung durch Hintergrundsystem (Datenbank, organisatorische/kommerzielle Anwendung/MES/ERP); (2) Ticket erstellen für Lizenzanwendung am Anwender-Gateway (Wizard mit oder ohne User-Interaktion); (3) Abholen eines Tickets (Autorisierung) zur Erstellung eines TPM gebundenen Fingerprints für Lizenzcontainer CmAct am Portal; (4) Erstellen des Fingerprints offline oder online in direkter Kommunikation am Portal, Einreichen Ticket + Fingerprint; (5) Abholen der Lizenz und Aktivieren der TPM gebundenen CmAct-Lizenz über Online- oder Offline-„Übertragungsweg“.

Sichere Datenspeicherung und Deployment (WIBU Systems AG)

Wie bereits oben im vorangegangenen Kapitel beschrieben, können durch die Tool- und Implementierungshilfen von CodeMeter lizenzgeschützte Dateien erzeugt und an die Embedded System eingebetteten TPM-Plattformen übertragen werden. Dazu sind Offline- und Online-Übertragungswege möglich. Für offline Übertragungswege sind die bekannten portablen Medien wie USB-Speichersticks oder Flashkarten einsetzbar, die von der Zielpattform basierend auf Linux unterstützt werden. Da lizenzgeschützte Datenfiles durch den Protector oder eine Anwendung bereits verschlüsselt sind, kann der Übertragungsweg je nach Anwendung für das Deployment von Dateien auch ungesichert erfolgen.

CodeMeter geschützte Datenträger im der CodeMeter Produktfamilie genannten Formfaktor bieten darüber hinaus noch besondere Vorteile für den Offline-Weg, da sich Lizenzcontainer und Datenspeicher auf einem gemeinsamen Medium befinden. Im Falle von spezifischen Use Cases ergeben für sich Embedded Systems mit TPM interessante, neue Lizenzanwendungen für Prozessinseln, die aus Gründen von Sicherheitsregeln nur in isolierten Netzwerken betrieben werden dürfen. Durch lokales, autarkes Lifecycle Management werden nur lizenzierte Files für ausführbare Software und assoziierte Datenfiles auf das Embedded System übertragen. Die Synchronisation von CodeMeter Lizenzen auf dem CodeMeter-Medium mit dem softwarebasierten, TPM gebundenen Lizenzcontainer CmAct erfolgt über die autarken Funktionen eines Aktivations Wizards. Das Auslesen des Fingerprints und das Rückspeichern der Lizenz können vollständig im Offline-Betrieb mit dem Embedded System erfolgen. Die Lizenzgenerierung bezogen auf den Fingerprint erfolgt am Gateway in Kommunikation mit der License Central.

Der Online-Transfer von lizenzierten Daten oder Dateien zwecks Speicherung auf einem Zielsystem kann über standardisierte IP-Protokolle (http/https) erfolgen. In Industrieanwendungen sind künftig entsprechend weitere Protokollanwendungen, wie in den OPC UA Standards spezifiziert, zu unterstützen. Im Arbeitspaket 1 wurde dieser Aspekt des sicheren Datenaustauschs von unverschlüsselten Daten oder Messages in der Ende-zu-Ende Kommunikation auf der Basis des eigenen CodeMeter SE bearbeitet. Hier im Kontext eines TPM gebundenen Lizenzcontainers als sicherem Speicher für sensitive, nicht auslesbare Schlüssel und „fest verankerten Zertifikaten“, vorgesehen zur Anbindung an ein OpenSSL Krypto-Interface, bietet der softwaregestützte Container ebenfalls verbesserten Schutz gegen Manipulation im Vergleich zur Ablage von Schlüsseln auf ungeschütztem Speicherbereich. Ein Aufbau von verschlüsselten Verbindungen über Trusted Channel kann jeweils nur über den autorisierten Zugriff auf valide Schlüssel und Zertifikate im Speicher des TPM gebundenen Lizenzcontainers erfolgen.

Die Integration der CodeMeter Runtime (CmEmbedded) auf der Linux-Zielpattform und die Implementierung für das CmAct Bindungsschema zur Anbindung an den TPM wurden durchgeführt. Angewendet wird ein Low Level SPI-Bindungsinterface für die TPM Version 1.2. Mit der Erstellung einer CmEmbedded-Implementierung für die TPM Version 2.0 konnte aufgrund der fortlaufenden Entwicklung am zu überarbeitenden Softwarestack parallel in einer späten Phase begonnen werden. Eine Adaption des Bindungsschemas über das TCTI Interface mit Kompatibilität zu den Linux Embedded Command Libraries ist geplant, sodass künftig eine Hardware unabhängige Implementierungshilfe für CmEmbedded ein Lizenz-Bindungsschema an einem TPM 2.0 bereitgestellt werden kann.

Kategorie Werkzeuge für Angriffserkennung & Evaluation der Schutzmaßnahmen

Industrielles Honeynet (DFKI)

Honeynets sind eine Agglomeration von Honeypots. Diese wiederum imitieren reale Systeme um Angreifer zu täuschen. Angriffe gegen Honeypots sind trivial zu erkennen, da außer ihnen, per Definition, keine Interaktion mit dem Honeypot stattfindet. Um die Reichweite von Honeypots zu erhöhen, werden sie zu den eingangs genannten Netzwerken erweitert.

Ziel dieses Ansatzes ist es sonst schwer zu erkennende Angriffe, z.B. bis dato unbekannte oder hochprofessionelle, zu detektieren und darüber hinaus weitere Informationen über den Angreifer, z.B. die eingesetzten Werkzeuge, ausgenutzten Schwachstellen oder die Motivation, zu erhalten. Diese Informationen sind außerordentlich wertvoll, um sensible Daten zu schützen und nachgelagerte Angriffsversuche sicher zu detektieren.

Die zu schützenden Systeme sind dabei meist über Ethernet-basierte Kommunikation zu einem Netzwerk verbunden. Es ist kein gesondertes Verständnis über das zu schützende System erforderlich, allerdings erhöhen realitätsnahe Imitationen die Kohärenz und erschweren Angreifern das Identifizieren und Vermeiden der Honeypots. Die entwickelte Lösung nutzt maschinelles Lernen um selbstständig das Netzwerkkumfeld zu verstehen und die Imitationen entsprechend zu verbessern. Gleichzeitig werden dadurch die Anforderungen an den Anwender reduziert.

Der entwickelte Prototyp kann in IP-basierten Netzwerken als Plug&Play-Lösung installiert werden. Ein manuelles Verbinden der Ethernetports an entsprechende Netzwerkhardware, typischerweise an einen Switch, ist der einzige erforderliche Schritt. Eine Feinjustierung des Systems kann darüber hinaus die Qualität des Honeynets weiter verbessern.

Die beschriebene Integration der Hardware sollte von den entsprechenden Netzwerkadministratoren vorgenommen werden. Die Überwachung von Alarmen kann sowohl lokal von eigenem Personal z.B. dem entsprechenden Netzwerkadministratoren, als auch über einen Dienstleister erfolgen.

Zusätzliche technische Informationen zum Thema Honeynet können den im Rahmen IUNO entstandenen Veröffentlichungen entnommen werden.

Die Anforderungen eines Honeynet sind als äußerst niedrig anzusehen, einfachste Hardware kann zehntausende Systeme imitieren.

Honeynets können maßgeblich zu Detektion von komplexen Angriffskampagnen und insbesondere Aufklärungsaktivitäten dienen und diese ebenfalls massiv stören. Sie dürfen allerdings nicht als alleiniges Angriffsdetektionswerkzeug, sondern nur als Ergänzung, genutzt werden.

Die in IUNO entwickelten autonomen Honeynets befinden sich im Prototypenstatus und sind aktuell nicht zum produktiven Einsatz geeignet. Kommerzielle Honeynet und HoneyPot Software ist verfügbar, erfordert aber oft manuelle Konfiguration und entsprechenden Expertenwissen und ist nur in wenigen Fällen für industrielle Anwendungen konzipiert. Die erforderlichen Maßnahmen zur Umsetzung sind im operativen Betrieb, vor allem im Incident Handling, dem Umgang mit detektierten Angriffen, verortet. Zwar sind genannte Systeme äußerst resistent gegen Falschalarme, allerdings ist auch bei diesem System Expertenwissen erforderlich, um verdächtige Aktivitäten weiter zu untersuchen und gegebenenfalls entsprechende Gegenmaßnahmen einzuleiten.

Der Einfluss auf weitere Systeme ist als gering anzusehen, da diese parallel zu dem Honeynet arbeiten und keine Interaktion intendiert ist. Allerdings sind Rückwirkungen auf weitere Überwachungssysteme, wie z.B. SIEM-Systeme, nicht auszuschließen, da diese gegebenenfalls aktiv Informationen über Systeme des Honeynets sammeln, welches dies als Angriffs- oder Aufklärungsaktivitäten identifizieren könnte und entsprechende Alarme auslöst.

Durch die fehlende Marktreife sind die Kosten nicht abzusehen, allerdings besteht die Referenzimplementierung ausschließlich aus quelloffener Software, welche in einem Rahmenwerk vereint wurde.

Input des Honeynet ist der Netzwerkkontext, welcher autonom erfasst wird. Darauf basierend verteilt sich das Honeynet im ungenutzten Bereich des Netzwerks. Von dort werden Alarme ausgelöst und über ein zu definierendes Protokoll an eine zu definierende Stelle gesendet.

Der Anwendungsraum ist als flexibel zu werten. Das Honeynet kann sowohl in KMUs als auch in größeren Unternehmen eingesetzt werden. Dabei ist für die Referenzimplementierung das Vorhandensein einer IP-basierten Netzwerkinfrastruktur Voraussetzung. Dies ist domänenübergreifend gegeben, damit ist keine Einschränkung durch die Domäne, die Projektgröße oder die Organisationsgröße zu erwarten.

Anomalieerkennung für industrielle Steuerungssysteme (DFKI, TU München)

Der stark wachsende Netzwerkverkehr in industriellen Anlagen durch den Einfluss der Digitalisierung und Industrie 4.0 erschwert weitestgehend das Auffinden von unbekannten Angriffen oder Mutationen bekannter Angriffe, die durch regelbasierte Systeme nicht erfasst werden können.

Mittels einer intelligenten Anomalieerkennung unter der Benutzung von klassischen und modernen Algorithmen maschinellen Lernens können sowohl solche Angriffe, als auch deren Angriffsart klassifiziert werden. Das von uns bereitgestellte System setzt sich aus Modulen zur

Datenaufarbeitung, dem eigentlichen Lernprozess und dem anschließenden Folgern (engl. inference) zusammen.

Zur Auswahl stehen neben der Implementierung von 13 klassischen Modellen ein Deep Neural Network, sowie ein Convolutional Neural Network. Weiter stellen wir Funktionen zur Korrektur von Überanpassungen (engl. overfitting, resp. underfitting) bereit. Extremwerte lassen sich außerdem in Form von Neuartigkeiten (engl. novelties) oder statistischer Ausreißer (engl. outliers) identifizieren und als Versuchsfehler relativ zum Datensatz anzeigen. Mittels der Implementierung zweiter Meta-Algorithmen lassen sich zudem ein mögliches Bias bzw. eine mögliche Varianz reduzieren.

Die wichtigsten Features lassen sich darüber hinaus grafisch ausgegeben und im Lernprozess zu Gunsten einer Dimensionsreduktion bzw. einer möglichen Performance-Steigerung selektieren. Zudem kann die Falsch-Positiv-Rate durch diesen Prozess ebenfalls reduziert werden.

Maschinelles Lernen bedingt im Allgemeinen wohlgeformte und hinreichend große Datensätze. Das überwachte Lernen, als eine Form dessen, bedarf darüber hinaus einer eindeutigen Zuordnung der aufgezeichneten Netzwerkpakete zu einem jeweiligen Angriff. Die Generierung der jeweiligen Datensätze für die Erstellung eines qualitativ gütigen Netzes setzen wir dem Anwender voraus, da dies sehr individuell entsprechend seiner Endanwendung ist.

Für die Nutzung der klassischen Algorithmen wird weiter keine spezielle Hardware benötigt. Deep Learning hingegen bedarf auf Grund der auf mehreren Ebenen arbeitenden neuronalen Netzen einer möglichst leistungsstarken GPU.

Zur aktiven Verwendung müssen sich Entwickler mit den Grundzügen neuronaler Netze und TensorFlow vertraut machen. Performance-Optimierungen erfordern darüber hinaus ein tiefgehendes Verständnis der zu nutzenden GPU-Architekturen und ihrer hardwarenahen Entwicklung.

Die Sicherheit im Wertschöpfungsnetzwerk wird erhöht, da neben allgemein bekannten Angriffsmustern insbesondere auch bisher noch unbekannte Netzwerkauffälligkeiten erkannt werden können.

Gleichzeitig ist das Frameworks für generelle Netzwerkdaten aller Anwendungsbereiche geeignet und durch neue Methoden und Optimierungen erweiterbar. Entscheidend für die jeweilige Anwendung sind trotz der generellen Einsetzbarkeit die zu Grunde liegenden Datensätze, die zwischen gewissen Anwendungsfällen erheblich voneinander divergieren können.

Abschließend müssen die Ergebnisse, z.B. ob ein Angriff vorliegt oder nicht, noch in einem weiteren Schritt verarbeitet werden. So ist bezugnehmend auf den Leitstand dieser in der Pflicht das Resultat auszuwerten und daraufhin entsprechend zu agieren. Die statistische Aussagekräftigkeit ist demnach eng mit der Anzahl der Daten, der Güte des Datensatzes, sowie der Wahl und Konfiguration der Modelle verbunden.

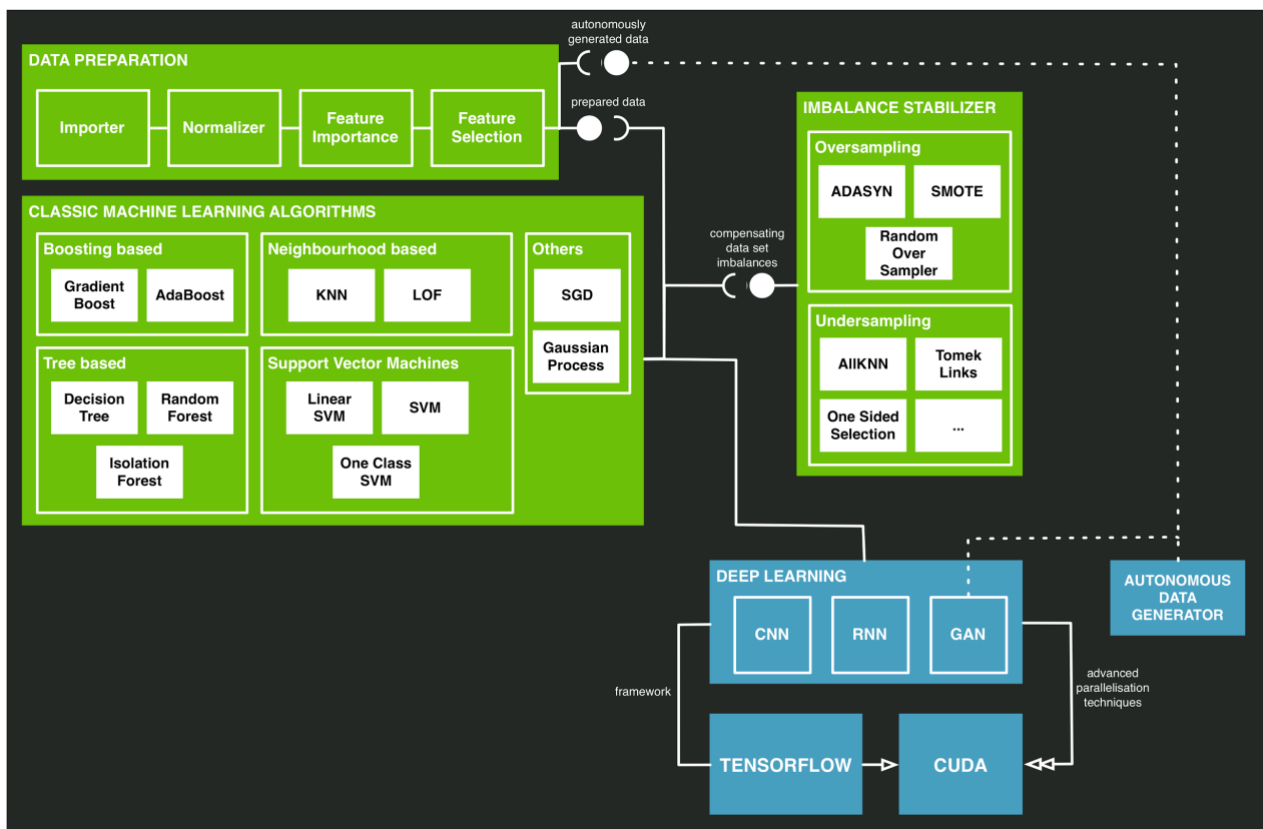


Abbildung 13: Übersicht der Bestandteile

Beschreibung einer weiteren Ausprägung

Der Lösungsbaustein besteht aus verteilten Sniffern, die lokal Daten aufnehmen und in der Lage sind, eine Paketanalyse auf Metaebene durchzuführen. Die verwendeten Algorithmen Support Vector Machines (SVM) und Random Forests wurden als geeignet evaluiert, Angriffe in beispielhaftem Modbus-Verkehr zu erkennen. Der Lösungsbaustein dient dazu, Angriffsmuster in industriellem Netzwerkverkehr durch lokale Vorverarbeitung zu detektieren. Weiterhin dient der Baustein dazu, eine Topologie des Netzwerkes zu erzeugen, um Beziehungen der Entitäten abzubilden und Anomalien zu verorten. Hierzu wird eine detaillierte Sicht auf das Netzwerk und alle Subnetze benötigt. Etwa durch SDN oder Port Mirroring können die benötigten Informationen ausgeleitet werden. Die Umsetzung findet unter der Federführung des Netzwerkadministrators statt. Die Lösungen werden ausführlich in den Veröffentlichungen des DFKI behandelt. Es wird zusätzliche Hardware benötigt, welche die Daten ausleitet und bewertet. Jedoch sind Standard-Bürorechner ausreichend. Weiterhin wird Zugang zur Netzwerkinfrastruktur benötigt. Das System hat das Potential, Angriffe aufzudecken, die durch Signaturprüfungen nicht zu erkennen sind. Zur Umsetzung muss die Software angepasst werden, jedoch nur in einigen, einfachen Parametern. Weiterhin muss für jedes Subnetz eine Hardwarelösung beschafft werden, sowie eine zentrale Kollektoreinheit. Abgesehen von der zusätzlichen Hardware und dem Zugang zur Netzwerkinfrastruktur ist ein Kanal notwendig, der die Kollektoren untereinander verbindet. Idealerweise handelt es sich hierbei um einen separaten Kanal. Die Dienste werden nicht beeinflusst, da der Kollektor rückwirkungsfrei arbeitet. Stattdessen werden Warnungen erzeugt, die den

Verantwortlichen bei der Entscheidungsfindung unterstützen sollen. Der größte Nachteil liegt in den Kosten für die Hardware und die Notwendigkeit eines zusätzlichen Kanals zur Kommunikation. Der Input ist Ethernet-basierter Netzwerkverkehr, der Output ist eine Bewertung, die auch in ein SIEM eingepflegt werden kann. Prinzipiell skaliert das System, bei voraussichtlich vertretbarem Hardware-Aufwand. Daher können auch große Organisationen profitieren, auch für kleine Organisationen ist die Anwendung geeignet.

Simulation von Produktionsnetzwerken (Fraunhofer AISEC)

Dieser Lösungsbaustein soll externe Fertigungsdaten, die durch zunehmend individualisierte Kundenwünsche entstehen, sicher in bestehende Produktionsprozesse integrieren. Kundenindividuelle Produktion ist eine der Chancen, die aus der Digitalisierung und der Innovation der Industrie 4.0 folgen. Durch die damit einhergehende Öffnung der Produktionsnetze birgt dies aber auch Risiken im Hinblick auf IT Sicherheit.

Die Erstellung der Produktdesigns erfolgt zunehmend durch Einbeziehung des Kunden. Die erstellten Designs werden an den Auftragnehmer der Fertigung über öffentliche Netze gesendet (vgl. Schritt 1 in Abbildung 14).

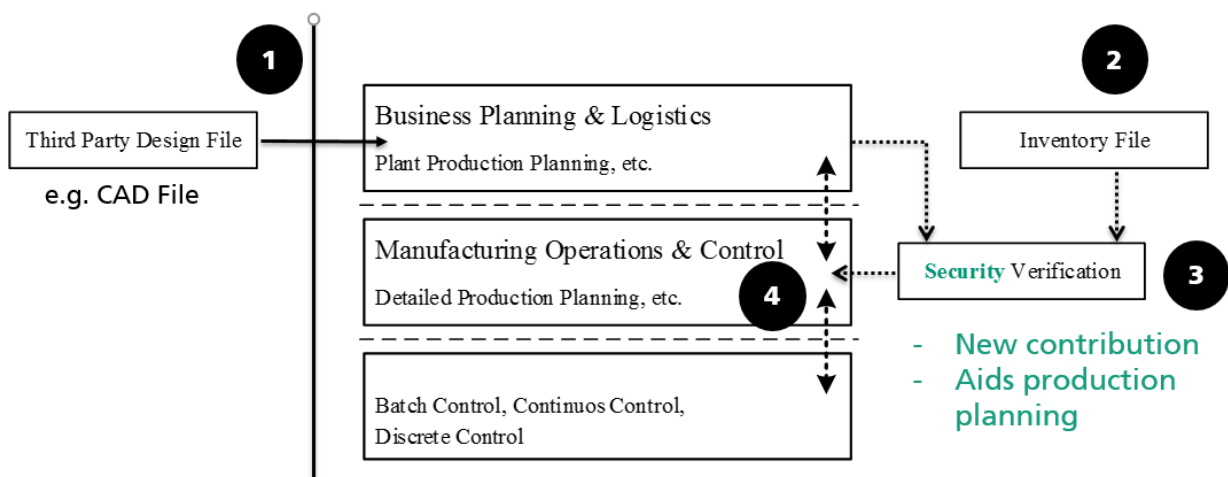


Abbildung 14: Ablauf kundenindividuelle Produktion

Durch eine Analyse der Konstruktionsdaten im Vorfeld zur realen Produktion lassen sich folgende zwei Aspekte prüfen:

- 1) Ist die gewünschte, kundenindividuelle Konfiguration technisch mit den vorhandenen Maschinen herstellbar?
- 2) Enthält die vorliegenden Konfiguration Parameter, welche die Fertigungsschritte der Maschinen außerhalb zulässiger Toleranzen betreiben würde? (vgl. Schritt 2 in der Abbildung 14).

So kann bspw. die Produktionsdatei einen Bohrvorgang an einer Glasoberfläche beinhalten, welche durch die Produktionsstraße so nicht umsetzbar ist. Das Resultat dieses Vorgangs mit ungeeignetem Werkzeug wäre die Zerstörung des Materials und die Beeinträchtigung der Verfügbarkeit der Produktion. Diese Beeinträchtigung ergibt sich durch Beschädigung der Werkzeugmaschine und durch unplanmäßige Wartungsarbeiten an der Anlage.

Bevor der Auftragnehmer die erhaltenen Konstruktionsdaten auf seiner Anlage fertigen lässt, können mit diesem Lösungsbaustein diese Daten analysiert werden (vgl. Schritt 3 in Abbildung 14).

Dieser erkennt neben den offensichtlichen Toleranzüberschreitungen die inhaltliche Plausibilität der Produktionsparameter. So können Probleme wie im obigen Fallbeispiel geschildert, bereits vor der Fertigung auf den realen Maschinen erkannt und abgefangen werden. Gleichzeitig wird bei vorhandenen technischen Gerätschaften ein erster Weg zur Fertigung des Produkts identifiziert. Dieser kann als erste Eingabe für die Planung der Produktion dienen.

Dazu wird die Produktbeschreibung zusammen mit Ihren Konstruktionsvorschriften in einem virtuellen Modell abgeglichen (vgl. Schritt 4 in Abbildung 14).

Es wird ein Graph-basierter Ansatz verwendet, um die einzelnen Prozessschritte der Produktion zu modellieren. Einzelne Schritte sind als Knoten im Graphen repräsentiert, wobei Kanten die möglichen Folgebearbeitungsschritte anzeigen. So lassen sich bereits etablierte und erforschte Methoden aus der Graphentheorie anwenden (vgl. Abbildung 15).

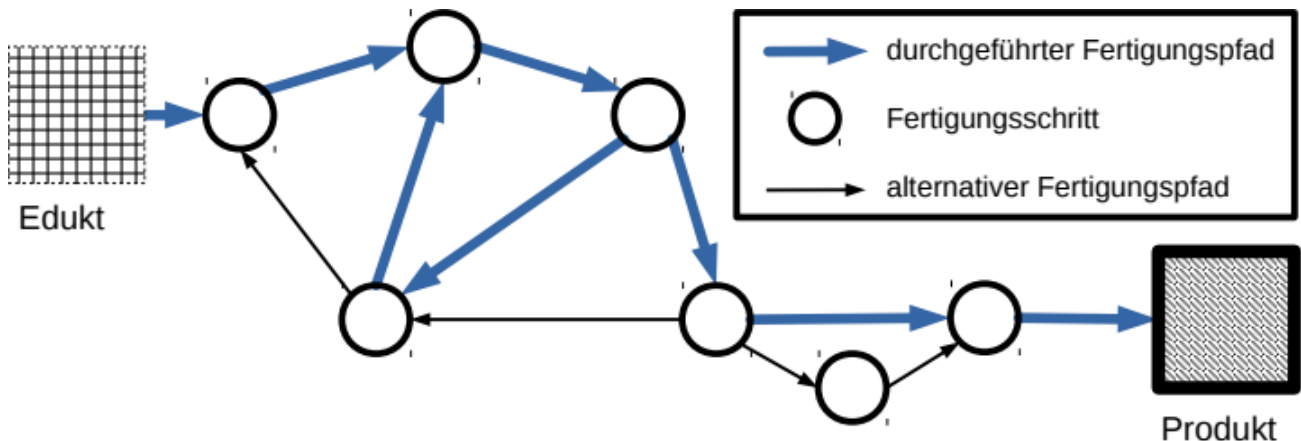


Abbildung 15: Virtueller Fertigungspfad durch die Anlage

Um diesen Lösungsbaustein in Systeme zu integrieren, sind entsprechende Modelle der Fertigungsmaschinen und der zu produzierenden Produkte erforderlich. Letztere sind meist bereits in Form von Produktionsdaten vorhanden, müssen ggf. um weitere Parameter ergänzt werden. Hierzu wird auf das etablierte XML Datenformat zurückgegriffen.

Die Simulation von Produktionsnetzen erwartet als Eingabegrößen je ein Modell des zu fertigenden Produkts sowie ein Modell der Fertigungsanlage. In IUNO wurden dazu Modelle in XML Darstellung verwendet. Modelle der zu fertigenden Produkte liegen meist in den angegliederten Systemen (MES, ERP) bereits in Form von Fertigungsdaten oder Auftragsdaten vor. Eine Beschreibung der Werkzeugmaschinen kann durch den Anlagenbauer erstellt werden und liefert damit ein Modell der Fertigungsanlage. Auf die jeweilige Domäne angepasst, kann der Lösungsbaustein dann die vorliegenden Modelle analysieren.

Die durchgeführte Plausibilisierung auf den virtuellen Modellen gibt einen ersten Indikator dafür, ob die gewünschte Konfiguration mit den vorhandenen Anlagen produzierbar ist. Wird der vorgestellte Ansatz zur virtuellen Vorab-Produktion umgesetzt, so können bereits durch die virtuelle Produktion potentiell schadhafte Konfigurationen identifiziert werden, welche die Verfügbarkeit der Anlagen beeinträchtigen würden. Durch Einsatz des vorgestellten Lösungsbausteins lässt sich die Verfügbarkeit der Anlage verbessern.

Weiter kann eine Aussage über den möglichen Fertigungspfad durch die Produktion getroffen werden, wenn sich ein Weg durch den Graphen ableiten lässt, so dass ein Rohwerkstück durch Traversieren des Pfades in das gewünschte Zielwerkstück überführt werden kann.

Dabei ist zu beachten, dass diese virtuelle Vorab-Analyse domänenspezifische Anpassungen erfordert. So ist je nach Einsatzgebiet eine geeignete Abbildung der Produktionsanlagen in einen Graphen zu definieren, in welchem die Rahmenbedingungen der Produktionsschritte abgebildet sind. Nur so ist es im Analyseschritt möglich, eventuell schadhafte Konfiguration zu detektieren bevor diese auf einer realen Anlage gefertigt werden.

Pentesting von industriellen Steuergeräten (Fraunhofer AISEC)

Wie zuvor erwähnt, liefern Risikoanalysen Erkenntnisse bezüglich Schutzbedarf eines Systems und der zu implementierenden Maßnahmen. Weiterhin basieren Teile solcher Analysen auf diversen Annahmen. Um nun diese Erkenntnisse und die getroffenen Annahmen bezüglich der tatsächlichen Implementierung eines Systems zu evaluieren, können Penetrationstests durchgeführt werden. Hier wird versucht, reale Angriffe auf Dienste, Geräte oder Anlagen durchzuführen und somit falsche Annahmen, mangelnde Umsetzung von Schutzmaßnahmen und andere Lücken zu erkennen. Solche Tests müssen schon frühzeitig bei Verfügbarkeit von Prototypen umgesetzt werden, damit noch eine Rückführung von Erkenntnissen das Gerät oder den Dienst möglich ist. Jedoch sollten auch bestehende Produkte und Anlagen derartig getestet werden, weil so akuter Handlungsbedarf ermittelt werden kann. Ebenso können aus Problemen in fertigen Produkten Lehren für zukünftige Entwicklungen gezogen werden.

Im Kontext des Projekts IUNO, und somit bezogen auf den Themenkomplex Industrie 4.0, liegt der Fokus von Penetrationstests auf eingebetteten Systemen und Fertigungsanlagen. Durch den dort anzutreffenden Einsatz von, im Vergleich zu Büro-IT, speziellen Hardwarekomponenten sowie Netzwerk- und Feldbusprotokollen, stellen sich besondere Herausforderung für die Herangehensweise und Umsetzungen von Penetrationstests. Diese Herausforderungen wurden in IUNO anhand exemplarischer Protokolle und Geräte ermittelt und dafür entsprechende Lösungsansätze entwickelt.

Für industrielle Anlagen ist der Einsatz von Feldbussen zur Kommunikation charakteristisch. Diese spielen weiterhin auch im Industrie 4.0 Kontext eine wichtige Rolle. Waren die Feldbusse traditionell eher isoliert für sich genutzt, werden sie immer weiter zu anderen Netzen und auch dem Internet geöffnet, um eine übergreifende Machine-to-Machine Kommunikation zu erreichen. So werden verstärkt Brückenelemente eingesetzt, welche zwischen der IP-Protokollfamilie und Feldbussen übersetzen. Im Rahmen von IUNO wurde mit Logboat (Plaga, Tatschner, & Newe, Logboat – A Simulation Framework Enabling CAN Security Assessments, 2016) ein Framework entwickelt, welches Untersuchungen des Controller Area Network (CAN) Feldbusses unterstützt. Es ermöglicht sowohl Simulation, Analyse von Kommunikation, als auch Fuzzing von CAN. Für Penetrationstest von industriellen Systemen sind hier vor allem die Analyse und Fuzzing Funktionalitäten hervorzuheben, da diese die Untersuchung und das Verständnis von auftretender Buskommunikation, sowie das Auffinden von Sicherheitslücken in den verwendeten Kommunikationsstacks erlaubt.

Durch die weiter fortschreitende Digitalisierung in der Industrie 4.0 steigt ebenso die Zahl der vernetzten Geräte. Zeitgleich müssen die Anlagen Fertigungsdaten zügig verarbeiten können, siehe individuelle Produktion mit "Stückzahl 1", was erneut die Anforderungen an das Gesamtsystem

erhöht. Die damit verbundenen höheren Anforderungen führen zu einer stark steigenden Komplexität der jeweiligen Hard- und Softwarekomponenten. Steuerungen in der Industrie 4.0 weisen, zusätzlich zu Feldbussen, oftmals eine weitere Schnittstelle, wie beispielsweise einen Netzwerkanschluss, auf und können darüber hinaus ein Betriebssystem besitzen. Die starke Vernetzung und Komplexität der Systeme führt dazu, dass nun Bedrohungen durch externe Angreifer betrachtet werden müssen, die in weniger stark digitalisierten Industriebereichen bisher außen vor geblieben sind.

Während sich in der Industrie 4.0 gerade erste Entwicklungen abspielen, existieren auf dem freien Markt bereits zahlreiche IoT-Geräte, deren Konzepte auch bald Einzug in die Industrie halten dürften. Diese Geräte sind ähnlich vernetzt, verwenden einen zentralen Service ("Cloud") zum Datenaustausch und verfügen über ein komplexes Betriebssystem. Um eine erste Einschätzung zu erhalten, wie derartige Geräte fachgerecht auf ihre Sicherheit getestet werden können und wie es um ihre Sicherheit bestellt ist, wurden im Jahr 2015 vier IoT Kamerasysteme durch das Fraunhofer AISEC sicherheitstechnisch im Detail untersucht, teils mit bedenklichen Ergebnissen (Obermaier & Hutle, Analyzing the Security and Privacy of Cloud-based Video Surveillance Systems, 2016). Die Analyse zeigte bei allen Geräten, dass diese Schwachstellen aufweisen. In manchen Fällen waren die Schwachstellen derart schwerwiegend, dass ein externer Angreifer von einem beliebigen Internetanschluss aus, das Gerät vollständig hätte außer Betrieb setzen können. Darüber hinaus waren sogar Manipulationen des aufgezeichneten Bildes möglich, ohne dass dies für den Betreiber ersichtlich oder zu verhindern gewesen wäre. In einem Industriekontext verursachen solche Schwachstellen schwerwiegende Auswirkungen, da sie Angreifern Tür und Tor nicht nur für Störungen des Systems öffnen, sondern den Betreiber bzgl. der korrekten Funktion seiner Anlage erpressbar machen.

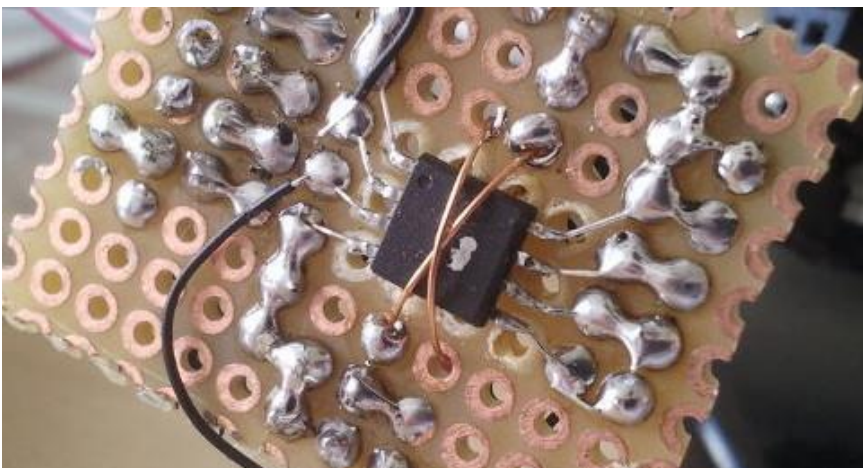


Abbildung 16: Nachdem der Speicherbaustein aus dem Gerät ausgelötet wurde, können die Daten extrahiert werden

In den Tests zeigte sich, dass die Sicherheit eines Geräts nicht anhand von trivialen Kriterien vorab beurteilt werden kann. Selbst die Verwendung von aktuell verfügbaren Standardwerkzeugen, wie beispielsweise für Port-Scans, brachte keinerlei auffällige Ergebnisse. Folglich waren automatisierte Testverfahren nicht für derartige Untersuchungen geeignet, da diese die vorhandenen schwerwiegenden Probleme nicht aufdecken konnten. Da derartige Methoden nicht zum Erfolg führten, wurde eine detaillierte Analyse der Systeme sowohl auf Hard- wie auch auf Softwareebene durchgeführt. Es wurde für jedes Gerät ein individuelles Vorgehen entwickelt, in welchem das System auf konzeptioneller Ebene überprüft wurde und Anforderungen im Anschluss praktisch

verifiziert bzw. falsifiziert wurden. Dies erforderte es teils, beispielsweise Speicherbausteine abzulöten (siehe **Error! Reference source not found.**) um deren Inhalte bzw. die Software des Systems zu analysieren. In weiteren Fällen wurde die interne Implementierung der Kommunikation in der Tiefe untersucht, wobei beispielsweise aufgedeckt werden konnte, dass die Geräte eines Herstellers alle mit dem gleichen Master-Passwort versehen sind - womit selbst eine stark verschlüsselte und gesicherte Kommunikation trivial ausgehebelt werden konnte. Dies zeigt sehr deutlich, dass, obwohl in einem ersten Schritt keine Auffälligkeiten erkennbar waren, die Sicherheit der Geräte letztendlich doch gebrochen werden konnte, da schwerwiegende Schwachstellen im Sicherheitskonzept vorlagen. Eine individuelle Überprüfung von Geräten ist daher sowohl auf Ebene des Grundkonzepts notwendig, als auch auf dessen Implementierung in der fertiggestellten Lösung. Diese Untersuchung hat gezeigt dass so etwas nicht generell und automatisiert erfolgen sollte, sondern individuell auf die jeweilige Anwendung angepasst. Nur so ist der sichere Einsatz von vernetzten Geräten im Kontext von Industrie 4.0 möglich.

Selbst wenn ein System auf *konzeptioneller* Ebene korrekt abgesichert wurde, können dennoch Schwachstellen in Hardwarekomponenten existieren, welche die Sicherheit des Gesamtsystems beeinträchtigen. So ist es beispielsweise bei Komponenten wie Mikrocontrollern entscheidend, dass diese durch einen Angreifer nicht ausgelesen oder manipuliert werden können. Diese Komponenten werden in den allermeisten Fällen zugekauft und dann beispielsweise vom Hersteller einer Steuereinheit eingesetzt. Somit muss ein weiterer Aspekt betrachtet werden, da meist keine Detailinformationen über das Niveau der gebotenen Sicherheit von zugekauften Mikrocontrollern vorliegen. Im Hinblick auf dieses Problem führte das Fraunhofer AISEC tiefergehende Analysen bzgl. Mikrocontrollersicherheit durch und erzielte neue Erkenntnisse (Obermaier & Tatschner, Shedding too much Light on a Microcontroller's Firmware Protection, 2017). Dies ist exemplarisch in **Error! Reference source not found.** dargestellt.

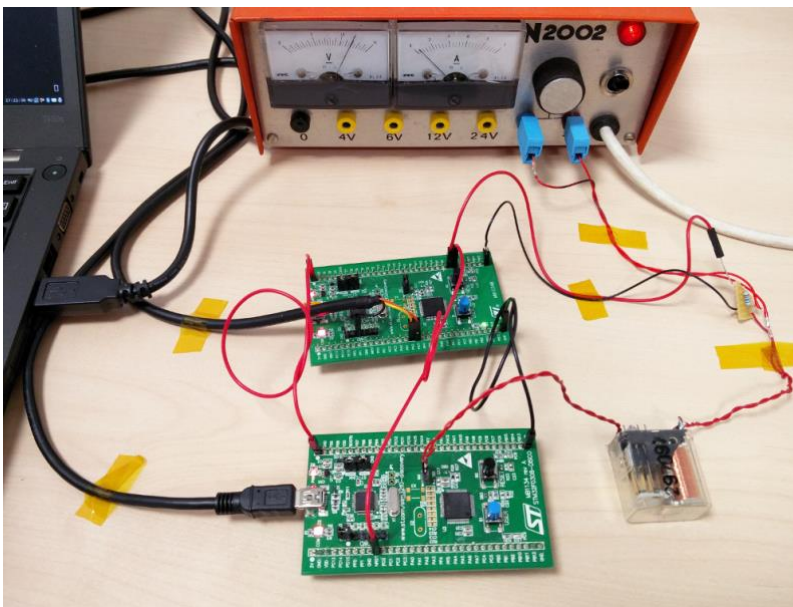


Abbildung 17: Exemplarische Sicherheitsanalyse eines Mikrocontrollers

Es gelang, den Ausleseschutz des Mikrocontrollers mit mehreren verschiedenartigen Ansätzen zu brechen und somit Geheimnisse aus dem System zu extrahieren. Dies zeigt, dass die Unsicherheit einer zugekauften Komponente die Sicherheit des Gesamtsystems zerstören kann. Es ist daher ein

ganzheitlicher Ansatz zu treffen, in welchem alle Komponenten des Systems in eine Sicherheitsanalyse bzw. einen Penetrationstest einbezogen werden.

In Geräten werden heutzutage neben Mikrocontrollern auch oftmals Field Programmable Gate Array (FPGAs) eingesetzt, welche ebenfalls nicht zum Einfallstor für potentielle Angreifer werden dürfen. Bei FPGAs handelt es sich um rekonfigurierbare Logik, d.h. diese Komponente kann nachträglich aktualisiert und mit neuen Modulen versehen werden. So können z. B. über einen Marktplatz Hardwarebeschleuniger für Signalverarbeitung o.Ä. bezogen werden in Steuerungsanlagen eingebracht werden. In einem FPGA existiert nicht nur der soeben genannte Hardwarebeschleuniger, darüber hinaus ist dieses oftmals als komplexes System on Chip (SoC) mit zahlreichen Zusatzmodulen wie beispielsweise Mikrocontrollern oder Kryptobeschleunigern konfiguriert. Das SoC übernimmt dabei weitere Aufgaben, beispielsweise als Maschinensteuerung. Da auch die übrigen Module auf einem FPGA vollen Zugriff auf den physischen Speicher haben, ist es möglich, über diese Komponenten beispielsweise in Software implementierte Absicherungsmaßnahmen auszuhebeln. Um Gerätearchitekturen auf derartige Anfälligkeiten zu testen, wurden am Fraunhofer AISEC verschiedene Angriffsszenarien auf einer kommerziell verfügbaren Plattform evaluiert. Dabei war es möglich, sowohl Integritätsschutz im Boot-Prozess zu umgehen (Jacob, Heyszl, Rolfes, Zankl, & Sigl, 2017), als auch geheimes Schlüsselmaterial zu extrahieren (Jacob, Rolfes, Zankl, Heyszl, & Sigl, 2017).

Integritätsüberwachung von Feldbusnachrichten (Siemens AG)

Die Sicherstellung der Integrität komplexer Produktionsanlagen, wie sie für die Industrie 4.0 typisch sind, ist essentiell für ihre Produktivität und die Qualität der Produkte. Unter Integrität einer Produktionsanlage ist hierbei zu verstehen, dass sich eine Anlage so verhält wie sie geplant und konfiguriert wurde. Wird die Integrität von Produktionsanlagen verletzt, kann dies zu Qualitätsproblemen der Produkte und zu einer eingeschränkten Verfügbarkeit der Produktion führen.

Neben der Integrität der beteiligten industriellen Komponenten trägt die Integrität der Kommunikation über Feldbusprotokolle zwischen diesen Komponenten wesentlich zum Systemverhalten bei. Bei der Spezifikation von Ethernet-basierten Feldbusprotokollen standen die Funktionalität und die funktionale Sicherheit (Safety) im Vordergrund. Kryptographische Sicherheitsmechanismen zur Authentifikation und Integritätssicherung der Nachrichten (Security) waren auch aus Gründen von Echtzeitanforderungen der Protokolle in der Vergangenheit nicht im Fokus. In aktuellen Industrie 3.0 Szenarien kann die Kommunikation auf Feld- und Steuerungsebene durch eine dem Risikobedarf gerechte Zonierung und der Umsetzung von Zellschutzkonzepten geschützt werden. Der Zugriff auf Komponenten einer Zone von Entitäten außerhalb der Zone ist stark reglementiert.

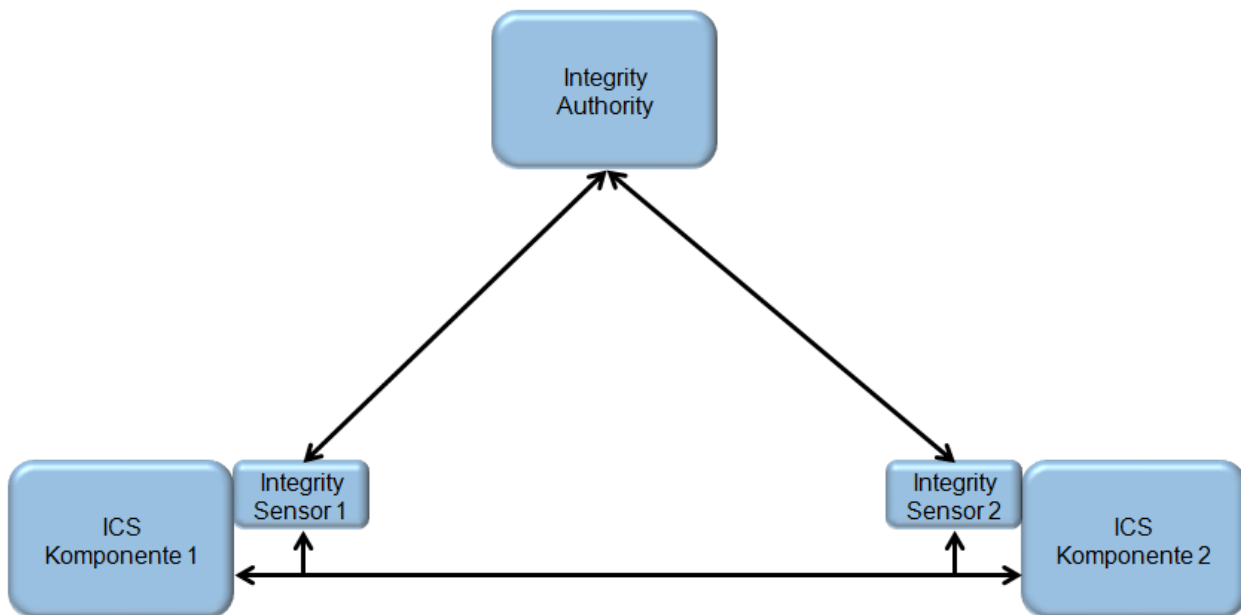


Abbildung 18: Architektur Integritätsüberwachung von Feldbusnachrichten

In zukünftigen Industrie 4.0-Szenarien wird die Flexibilität der Kommunikationsbeziehungen zunehmen. Statische Ansätze zum Schutz der Komponenten auf Feldebene können nicht mehr das gleiche Schutzniveau bieten wie dies heute möglich ist. Zudem besteht aus Sicht eines Betreibers der Bedarf, Manipulationen der Kommunikation frühzeitig zu detektieren.

Um diesen Anforderungen gerecht zu werden wurde in IUNO ein Werkzeug von Siemens prototypisch entwickelt und erprobt, das eine passive Überwachung der Integrität von Ethernet-basierten Feldbusnachrichten ermöglicht. Die Integrität der Nachrichten wird hierbei kontinuierlich durch Integrity-Sensoren ermittelt.

Diese Sensoren nehmen an Hand von Filterkriterien den Datenverkehr zwischen industriellen Komponenten auf und berechnen kryptographische Integritätsreferenzwerte. Das Monitoring erfolgt rückwirkungsfrei für die Feldbusprotokolle, um die Automatisierungsprozesse nicht zu beeinflussen. Die Integritätsreferenzwerte werden in einer übergeordneten Instanz korreliert und geprüft. Damit lässt sich zeitnah feststellen, ob Inhalte von Feldbusnachrichten auf ihrem Weg durch das Netzwerk verändert wurden, oder ob Nachrichten unautorisiert in das Automatisierungsnetzwerk eingespielt wurden.

Bewertung und Ausblick

Für den nachhaltigen Markterfolg von Unternehmen ist ein angemessenes Niveau an IT-Sicherheit erforderlich. Für viele Unternehmen, insbesondere für kleine und mittlere Unternehmen (KMU) aus dem Bereich der industriellen Fertigung und des Maschinenbaus, stellt dies eine große Herausforderung dar. Diese ergibt sich aus der Geschwindigkeit des technologischen Wandels und geht mit ihm einher. Dieser Wandel entsteht aus dem gesellschaftspolitisch relevanten Thema der Digitalisierung, welche auf KMU durch die Industrie 4.0 einwirkt. Beide Spannungsfelder, IT-Sicherheit und Industrie 4.0, können nicht getrennt voneinander betrachtet werden, da sie eine langfristige Technologiestrategie der Unternehmen erfordern.

Das nationale Referenzprojekt zur IT-Sicherheit in Industrie 4.0 (IUNO) hat sich mit der Erarbeitung einer IT-Sicherheits-Referenzarchitektur für Industrie 4.0 beschäftigt und in diesem Rahmen methodische Ansätze zur Bedrohungs- und Risikobewertung industrieller Einsatzumgebungen sowie Lösungskonzepte erforscht, prototypisch umgesetzt und anhand von Demonstratoren deren Mehrwert aufgezeigt. Die Ergebnisse von IUNO stellen ein sehr gutes Fundament dar, auf dem konsequent aufgesetzt werden kann, so dass aus den Prototypen Technologiebausteine, Methoden und Werkzeuge mit einer hohen Einsatzreife entwickelt werden können. Diese können dann nicht nur von den Partnern aus dem Projekt sondern insbesondere auch von anderen Interessenten, bspw. von Technologieanbietern und Unternehmen oder Dienstleistern, zur weiteren Vermarktung aufgegriffen werden.

Manche der betrachteten Lösungsbausteine können sowohl direkt in – zu den IUNO Anwendungsfällen – vergleichbare Anwendungsszenarien eingesetzt werden, als auch in anderen Konstellationen angewendet werden. Beispiele dafür sind u.a. die Lösungsbausteine für Bedrohungs- und Risikoanalysen, iTPM, Durchsetzung von Datennutzungsrichtlinien, Softwareschutz und -lizenzierung, Sichere Datenspeicherung oder Pentesting. Einige andere Bestandteile des Werkzeugkastens bedürfen anwendungsspezifischer Anpassungen oder weitere Vorlaufentwicklung.

Aus der intensiven Zusammenarbeit mit Unternehmen der produzierenden Industrie wurden Anforderungen identifiziert, die zu erfüllen sind, um die IUNO-Ergebnisse auch für kleine und mittlere Unternehmen nutzbar zu machen. Eine wesentliche Herausforderung ist, dass KMU Schwierigkeiten haben, ihr eigenes Sicherheitsniveau zu bewerten, zu verstehen und insbesondere daraus eine Strategie zur systematischen, risikobasierten Verbesserung ihres Sicherheitsniveaus abzuleiten, um so zu nachhaltig widerstandsfähigen Infrastrukturen zu gelangen. Trotz des vielfältigen Angebots an kommerziellen Werkzeugen, können Unternehmen ohne eine geeignete methodische und fachliche Unterstützung meist nicht qualifiziert entscheiden, wie IT-Sicherheit in bestehende Unternehmensprozesse, insbesondere unter Kosten-Nutzen-Aspekten, sinnvoll integriert werden kann bzw. mit welchen gezielten Maßnahmen eine systematische Migration in ein höheres Sicherheitslevel erfolgen kann. Es existieren zwar viele verschiedene Ansätze und Modelle eine Sicherheitsbewertung durchzuführen, allerdings sind diese von KMU nur mit externer Unterstützung anwendbar, da intern die dafür erforderliche Expertise in den meisten Fällen noch nicht umfassend vorhanden ist.

Bei Fragen zu bestimmten Werkzeugen stehen einerseits die IUNO-Beteiligten als direkte Ansprechpartner zur Verfügung und andererseits gerne auch das Fraunhofer AISEC als Hauptansprechpartner zu generellen Fragen rund um die in IUNO erarbeiteten Werkzeuge und Lösungsbausteine. Anfragen können an info@aisec.fraunhofer.de gesendet werden.

Referenzen

- Arthur, W., & Challenger, D. (kein Datum). *A Practical Guide to TPM 2.0: Using The New Trusted Platform Module In The New Age of Security*.
- Eichler, J., & Angermeier, D. (2015). Modular risk assessment for the development of secure automotive systems. 31. VDI/VWGemeinschaftstagung Automotive Security.
- Giehl, A., & Schneider, P. (01 2018). Sichere Prozesse für moderne Geschäftsmodelle. *Zeitschriftenartikel Industrie 4.0 Management, Schwerpunkt "Fabriksicherheit"*.
- Hansch, G., Schneider, P., & Plaga, S. (2017). Packet-wise Compression and Forwarding of Industrial Network Captures. *IDAACS 2017*. <https://ieeexplore.ieee.org/document/8095051>.
- Jacob, N., Heyszl, J., Rolfes, C., Zankl, A., & Sigl, G. (2017). How to Break Secure Boot on FPGA SoCs through Malicious Hardware. *Conference on Cryptographic Hardware and Embedded Systems*.
- Jacob, N., Rolfes, C., Zankl, A., Heyszl, J., & Sigl, G. (2017). Compromising FPGA SoCs using Malicious Hardware Blocks. *Design, Automation and Test in Europe*.
- Obermaier, J., & Hutle, M. (2016). Analyzing the Security and Privacy of Cloud-based Video Surveillance Systems. *Proceedings of the 2nd ACM Work-shop on IoT Privacy, Trust, and Security. IoTPTS '16*.
- Obermaier, J., & Tatschner, S. (2017). Shedding too much Light on a Microcontroller's Firmware Protection. *11th USENIX Workshop on Offensive Technologies (WOOT 17)*. Vancouver, BC: USENIX Association.
- Plaga, S., Niethammer, M., & Wiedermann, N. (2018). Adding Channel Binding for an Out-of-Band OTP Authentication Protocol in an Industrial Use-Case. *The 1st International Conference on Data Intelligence and Security*. <https://ieeexplore.ieee.org/document/8367772>.
- Plaga, S., Tatschner, S., & Neue, T. (2016). Logboat – A Simulation Framework Enabling CAN Security Assessments. *IEEE Applied Electronics Conference 2016*. Pilsen.
- Plaga, S., Wiedermann, N., Hansch, G., & Neue, T. (June 2018). Secure your SSH Keys! - Motivation and Practical Implementa-tion of a HSM-based Approach Securing Private SSH-Keys. *17th Conference on Cyber Warfare and Security*. Oslo Norway.
- Sergej Proskurin, J. K. (2018). Follow the WhiteRabbit: Towards Consolidation of On-the-Fly Virtualization and Virtual Machine Introspection. *Proceedings of the International Conference on ICT Systems Security and Privacy Protection (IFIP SEC)*.
- Wiedermann, N., & Plaga, S. (2018). Rowhammer - A Survey Assessing the Severity of this Attack Vector. *Embedded World Conference 2018*. Nuremberg Germany: isbn: 978-3-645-50173-6.